SIGPN-T — Évolution du module biométrique : spécifications techniques, version 1.2

Police nationale du Tchad — Éditeur : TECHNOTCHAD — Version 1.2 du 11 novembre 2026 — Document de conception à soumettre à des validateurs externes

Rubrique	Valeur
Statut	**Conception. Aucune implémentation n'est autorisée.** Cette version intègre intégralement les **30 anomalies** de la revue indépendante de la version 1.1 (2 critiques, 14 majeures, 12 moyennes, 2 mineures)
Remplace	`SPEC_EVOLUTION_BIOMETRIQUE_V1.1` (commit `31adc24`) ; la revue examinée est `REVUE_INDEPENDANTE_V1.1` (commit `54b0bdf`)
Mode	**Documentation uniquement** : aucun code, aucune table, aucune donnée, aucune configuration modifiés ; **aucune migration exécutée** ; aucun commit poussé
Marqueurs DEMO	**Conservés** (chapitre 20)
Moteur réel	**Aucun n'est connecté** et aucun ne le sera sans les conditions des chapitres 11 et 12
Validation externe obligatoire	Cette version doit être soumise à **un architecte sécurité externe, un juriste et un responsable indépendant de la protection des données** avant toute autorisation d'implémentation (checklists du chapitre 14.3). Elle n'a **pas** été validée par eux
Livrables associés	Registre des 23 décisions · Registre des 25 risques · Tableau de traçabilité des 30 anomalies · Diagrammes techniques

1. Objectif, principes et périmètre
2. Modèle de menace p. 2
3. Architecture technique cible p. 2
4. Ce qui change entre la version 1.1 et la version 1.2 p. 3
5. Étape 1 — Séparation des privilèges PostgreSQL et exploitation (A-01) p. 3
6. Étape 2 — Intégrité cryptographique des événements et décisions (A-02, A-03, A-06, A-07) p. 5
7. Étape 3 — Sauvegardes, restauration et registre d'effacement (A-04, A-05, A-16) p. 7
8. Étape 4 — Architecture du coffre de clés (A-11, A-12, A-13)
9. Étape 5 — Séparation des responsabilités au niveau des personnes physiques (A-19, A-20, A-21, A-22) p. 11
10. Étape 6 — Bases légales multiples et précédence preuve / effacement (A-14, A-15) p. 13
11. Étape 7 — Portabilité AFIS et interdiction des essais prématurés (A-08, A-09) p. 14
12. Étape 8 — Les neuf phases : critères mesurables, collecte encadrée, retour arrière (A-23, A-24, A-25, A-26) p. 16
13. Étape 9 — Décisions D-17 à D-23, fédération avec le Dossier unique national (A-10, A-17, A-18, A-27) p. 20
14. Étape 10 — Registre des risques et checklists de validation externe (A-28, A-29, A-30) p. 23
15. Modèle de données consolidé v1.2 p. 26
16. API et contrats fournisseurs consolidés p. 27
17. Workflows
18. Rôles et permissions (préservation des 29 rôles et des 158 droits) p. 29
19. Plan de tests et de validation p. 29
20. Plan de migration depuis le mode DEMO p. 29
21. Fichiers et composants existants susceptibles d'être modifiés (repérage, **aucun n'est modifié**) p. 30
22. Soumission aux validateurs externes p. 30

Annexe A — Tableau de traçabilité des 30 anomalies p. 30

1. Objectif, principes et périmètre

Objectif. Faire évoluer par étapes le module de démonstration en une solution biométrique sécurisée, interopérable et indépendante de tout fournisseur, **dont l'inviolabilité tient même face à un administrateur privilégié**.

Principes directeurs de la version 1.2 (les huit de la version 1.1 sont conservés, quatre sont ajoutés).

1. **Conserver et ne rien retirer** aux rôles, droits, modules et écrans existants ; toute évolution est additive.
2. **Deux chemins étanches** : DEMO (inchangé) et réel (nouveau modèle) ; aucune donnée réelle dans le chemin DEMO et inversement.
3. **Réutiliser les quatre interfaces** de `providers/types.ts` ; extensions facultatives seulement.

TECHNOTCHAD

4. **Un résultat est une indication**, jamais une preuve ni un ordre d'agir.
5. **Indépendance vis-à-vis du fournisseur** (D-03 option B obligatoire).
6. **Interopérabilité** par identifiant de sujet stable et connecteur versionné, **sans divulgation sortante**.
7. **Interdiction absolue** d'utiliser un hachage SHA-256 d'une image comme gabarit biométrique.
8. **Aucune donnée biométrique réelle** hors production, ni avant le statut requis du fournisseur.
9. **Défense en profondeur face au privilégié** : aucune garantie d'intégrité ne repose sur un seul administrateur, un seul compte ou un seul système.
10. **Séparation des fonctions au niveau de la personne physique**, pas seulement du compte.
11. **Preuve d'intégrité vérifiable à l'extérieur** : tout événement important est inscrit dans un registre chaîné, signé et ancré hors de l'exploitation.
12. **Corroboration obligatoire** : aucune mesure coercitive sur la seule base d'un résultat biométrique.

1.1 Correspondance entre les priorités demandées et les dix étapes de la revue

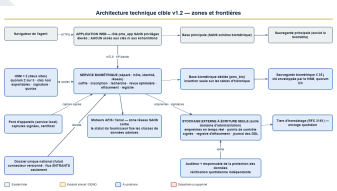
Priorité demandée	Étape de la revue (ordre respecté dans ce document)	Chapitre
1. A-01 : séparation des privilèges PostgreSQL	**Étape 1**	5
2. A-02 : intégrité cryptographique des événements et décisions	**Étape 2**	6
3. Sauvegardes et restauration	**Étape 3**	7
4. Architecture du coffre de clés	**Étape 4**	8
5. Séparation des responsabilités au niveau des personnes physiques	**Étape 5**	9
(conservation, bases multiples, précédence)	**Étape 6**	10
6. Portabilité AFIS et interdiction des essais prématurés	**Étape 7** (+ D-03 à l'étape 9)	11, 13
8. Neuf phases mesurables	**Étape 8**	12
7. Fédération avec le Dossier unique national · 9. Décisions D-17 à D-23	**Étape 9**	13
10. Reclassement des risques	**Étape 10**	14

2. Modèle de menace

Adversaire	Capacités supposées	Biens visés	Contrôles principaux (chapitres)
Administrateur de la plate-forme	Accès au serveur, à l'environnement, éventuellement à la base	Historique, gabarits, configuration	Rôles PostgreSQL séparés, tripwire, registre ancré (5, 6)
Administrateur de base de données	Superutilisateur possible, restauration	Historique, effacements	Superutilisateur scellé et alerté, restauration à quorum, ancrage externe (5, 6, 7)
Développeur malveillant ou compromis	Modification du code	Clés, contrôles, droits	Service biométrique séparé, épinglage en base, revue du code, HSM (8, 9)
Agent initié (enquêteur, relecteur)	Compte légitime	Données de personnes, décisions	Cible partie à l'affaire, anomalies, revue en aveugle, corroboration (9, 10, 15)
Fournisseur du moteur	Accès au moteur, aux sondes	Données réelles	Classes de données, statuts, zone réseau, contrat (11)
Attaquant externe	Intrusion de l'application web	Déballage massif, exfiltration	Service biométrique séparé, quotas, coupe-circuit (8)
Personne à double identité	Deux comptes pour une personne	Séparation des fonctions	Identité d'agent, réconciliation (9)
Autorité hors cadre	Pression pour un usage détourné	Finalité	Base légale, DPO indépendant, audit externe (13, 14)

Hypothèses. Le HSM, le support d'ancrage externe et le tiers d'horodatage ne sont **pas** administrés par les mêmes personnes que la base et l'application ; les gardiens des clés sont au moins trois personnes distinctes.

3. Architecture technique cible



Zone	Composants	Particularités
Application web	Écrans, API existantes (enveloppes minces), orchestrateur	**Aucun accès aux clés ni aux échantillons en clair** ; rôle de base `pms_app` sans privilèges élevés
Service biométrique (nouveau)	Coffre, inscription, recherche, matériel de revue éphémère, effacement, registre biométrique	Hôte, identité et réseau distincts ; base biométrique dédiée ; quotas de déballage
HSM (deux appareils)	Clés maîtresses non exportables, clés de signature, clé de pseudonymes	Quorum natif ; rôles HSM séparés
Moteurs AFIS et facial	Fournisseurs	Zone réseau dédiée sans sortie ; statut gouvernant les classes de données
Stockage externe à écriture seule	Empreintes du registre, points de contrôle signés, registre d'effacement, journal des DDL	Autre domaine d'administration ; tiers d'horodatage
Dossier unique national (futur)	Connecteur versionné	Flux **entrants** par défaut
Base principale	Données de l'application	Sauvegarde sans le schéma biométrique

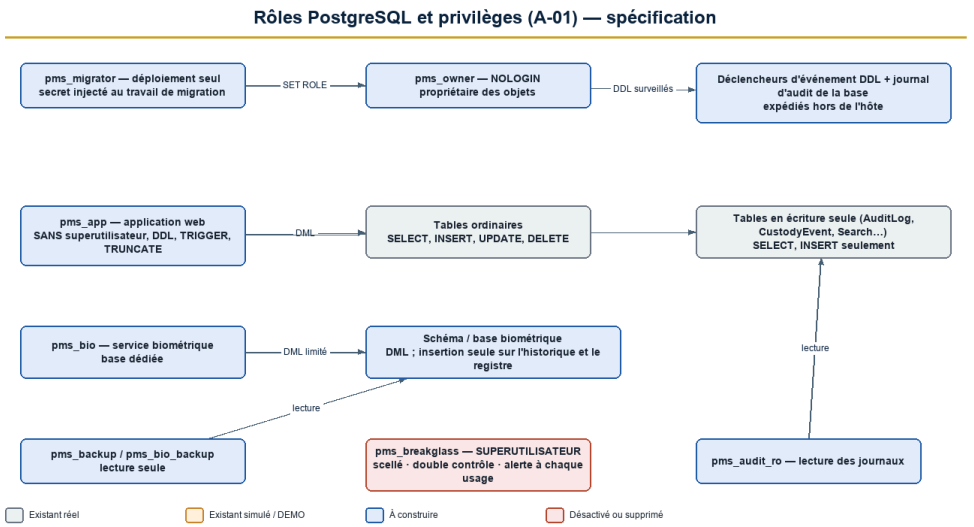
Frontières. (1) Le navigateur ne parle jamais au moteur ni au service biométrique ; (2) l'application ne détient aucune clé ; (3) le service biométrique n'expose aucun point de déchiffrement en masse ; (4) toute communication est chiffrée et authentifiée mutuellement ; (5) les sondes ne sont jamais conservées ; (6) les échantillons de référence sont chiffrés dans le coffre (D-03).

Performances (inchangées) : 1:1 p95 ≤ 2 s ; 1:N p95 ≤ 10 s, la galerie restant dans le moteur ; « indisponible » n'est jamais « aucune correspondance ».

4. Ce qui change entre la version 1.1 et la version 1.2

Domaine	Version 1.1	Version 1.2
Privilèges de base	« Rôles de base séparés » invoqués, inexistants	**Cinq rôles PostgreSQL**, tripwire, `REVOKE`, surveillance des DDL (ch. 5)
Intégrité	Déclencheurs seuls	**Registre chaîné, points de contrôle signés par le HSM, ancrage externe** (ch. 6)
Restauration	Non encadrée ; registre d'effacement en base	**Quorum natif, quarantaine, comparaison aux ancrages, registre d'effacement externe** (ch. 7)
Coffre	Dans l'application	**Service biométrique séparé**, quotas, HSM à quorum, cycle de vie, AAD (ch. 8)
Séparation	Au niveau du compte	**Identité d'agent**, épinglage, éligibilité par type, amorçage (ch. 9)
Conservation	Une base légale	**Bases multiples**, précédence (ch. 10)
Fournisseurs	Double fonctionnement avant évaluation	**Classes de données et statuts**, ordre corrigé, essai bi-fournisseur (ch. 11)
Phases	Critères qualitatifs	**Critères mesurables, phase 3b, retour arrière en cinq classes** (ch. 12)
Fédération	`attest()`	**Supprimé** ; flux ; scissions ; mode dégradé (ch. 13)
Décisions	16	**23**
Risques	10	**25**, reclassés (ch. 14)

5. Étape 1 — Séparation des privilèges PostgreSQL et exploitation (A-01)



5.1 Constat à corriger

Le compte `pms_app` est propriétaire des tables **et** superutilisateur (vérifié) ; la configuration de production utilise le même identifiant pour le cluster et l'application. Les déclencheurs d'écriture seule (`AuditLog`, `CustodyEvent`) sont donc **désactivables par l'application**.

5.2 Rôles cibles (spécification, non appliquée)

Rôle	Connexion	Droits	Usage
`pms_owner`	**Aucune**	Propriétaire des schémas et objets	Jamais utilisé en connexion
`pms_migrator`	Oui, **secret injecté au seul travail de migration**	Membre de `pms_owner` (changement de rôle) ; DDL	`prisma migrate deploy` au déploiement
`pms_app`	Oui	`SELECT, INSERT, UPDATE, DELETE` sur les tables ordinaires ; **`SELECT, INSERT` seulement** sur les tables en écriture seule (`AuditLog`, `CustodyEvent`, `BiometricMatch`, `BiometricReview`…) ; **tables mixtes DEMO / réel** (`BiometricSearch`, `BiometricControl`) : `SELECT, INSERT` plus **droits de colonne limités** (`UPDATE` sur `action`, `actionNotes`, `actionById`, `actionAt` ; états des contrôles simulés), le déclencheur par ligne interdisant toute modification d'une ligne réelle — en production sans ligne DEMO, ces droits de colonne sont retirés ; **ni `TRUNCATE`, ni `TRIGGER`, ni `REFERENCES`, ni `CREATE`** ; **ni superutilisateur, ni propriétaire**	Application web
`pms_bio`	Oui (service biométrique seulement)	DML sur la base biométrique dédiée ; insertion seule sur le registre	Service biométrique
`pms_backup` / `pms_bio_backup`	Oui	Lecture seule (`pg_read_all_data`) ; la sauvegarde principale **exclut** le schéma biométrique	Sauvegardes
`pms_audit_ro`	Oui	`SELECT` sur les journaux	Vérificateur d'audit
`pms_breakglass`	Oui, **scellé**	Superutilisateur	Secours : double contrôle, alerte immédiate à chaque usage, journal externe

5.3 Mesures complémentaires

1. `REVOKE UPDATE, DELETE, TRUNCATE` des tables en écriture seule pour `pms_app` ; `REVOKE CREATE ON SCHEMA public`.
2. **`pg_hba`** : une ligne par rôle et par origine ; **TLS obligatoire** ; `scram-sha-256`.
3. **Déclencheurs d'événement** (`ddl_command_end`, `sql_drop`) et journal d'audit de la base enregistrant tout DDL, tout changement de rôle, toute modification d'un déclencheur ; **expédition hors de l'hôte** vers le support externe (chapitre 6).
4. **Tripwire** au démarrage : l'application consulte son propre rôle et **refuse de démarrer** s'il est superutilisateur, propriétaire d'un objet, ou s'il possède `CREATE`/`TRIGGER`.
5. **Migrations hors du conteneur applicatif** (`deploy/entrypoint.sh` ne lance plus `migrate deploy`) ; deux URL distinctes (`DATABASE_URL` pour l'exécution, URL de migration pour le déploiement).
6. **Secrets** : le mot de passe du superutilisateur de secours est scellé (deux personnes) ; aucun secret de migration ni de secours n'est présent sur l'hôte applicatif.
7. **Environnement de développement** : le poste de développement conserve ses facilités (superutilisateur local) ; **les tests d'attaque s'exécutent sur un profil durci** (préproduction), jamais sur le poste de développement.

5.4 Tests d'attaque (exécutés en tant que `pms_app`)

`UPDATE`/`DELETE`/`TRUNCATE` sur chaque table en écriture seule ; `ALTER TABLE … DISABLE TRIGGER` ; `SET session_replication_role = replica` ; `CREATE TABLE` / `CREATE FUNCTION` ; `DROP TRIGGER` ; lecture du schéma biométrique : **tous doivent échouer (code 42501)**. Test d'introspection : `rolsuper = faux`, propriétaire ≠ rôle applicatif, `has_table_privilege` conforme. Test du tripwire : démarrage refusé avec un rôle excessif.

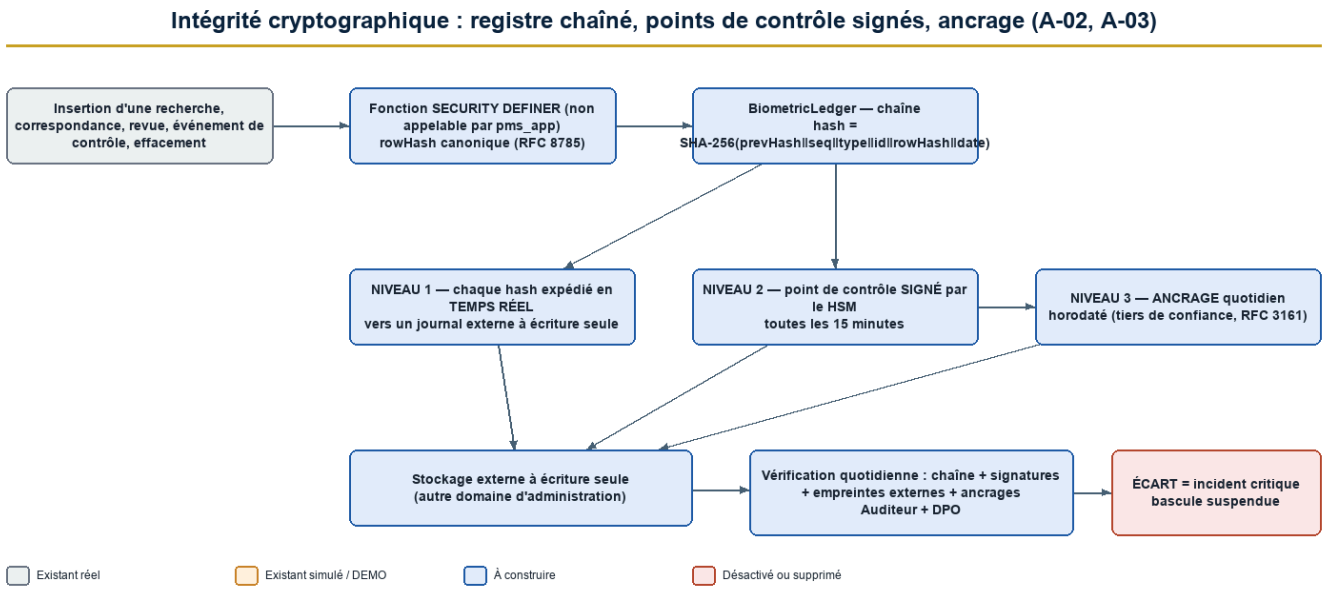
5.5 Fiches des anomalies de l'étape 1

A-01 — Compte applicatif propriétaire des tables et superutilisateur

Élément	Contenu
Anomalie initiale	Compte applicatif propriétaire des tables et superutilisateur — gravité **Critique**, statut de la revue **NON VALIDÉ**

Correction précise	Cinq rôles PostgreSQL distincts : propriétaire de schéma sans connexion ; migrateur utilisé seulement au déploiement ; **rôle applicatif sans DDL, sans TRIGGER, sans TRUNCATE, ni superutilisateur, ni propriétaire** ; rôle du service biométrique sur base dédiée ; rôle de sauvegarde en lecture seule. `REVOKE UPDATE, DELETE, TRUNCATE` sur les tables en écriture seule ; tables mixtes DEMO/réel : droits de colonne limités + déclencheur par ligne. `pg_hba` par rôle et origine, TLS et `scram-sha-256` obligatoires. Surveillance des DDL (déclencheur d'événement + journal d'audit de la base) **expédiée hors de l'hôte**. **Tripwire** : l'application refuse de démarrer si son rôle est superutilisateur ou propriétaire. Superutilisateur de secours scellé (double contrôle, alerte à chaque usage). Tests d'attaque exécutés en tant que rôle applicatif (refus attendu, code 42501).
Composants concernés	`deploy/docker-compose.yml`, `deploy/entrypoint.sh` (migrations hors du conteneur applicatif), `deploy/backup/*`, `prisma/schema.prisma` (URL de migration distincte), `src/server/db.ts` (tripwire), `src/server/env.ts`, scripts SQL d'initialisation (nouveaux), tests d'attaque (nouveaux)
Risques résiduels	Superutilisateur de secours existant (scellé, alerté) ; collusion de deux administrateurs ; le poste de développement conserve un superutilisateur (hors production)
Validations nécessaires	Architecte sécurité externe (revue des rôles et de `pg_hba`) ; exécution des tests d'attaque en préproduction ; test d'intrusion ciblé
Chapitre	5

6. Étape 2 — Intégrité cryptographique des événements et décisions (A-02, A-03, A-06, A-07)



6.1 Registre biométrique chaîné

`BiometricLedger(seq, type, entityId, rowHash, prevHash, hash, at)`. Alimenté par des **fonctions `SECURITY DEFINER`** (non appelables directement par `pms_app`) déclenchées à chaque insertion dans `BiometricSearch`, `BiometricMatch`, `BiometricReview`, `BiometricControlEvent` et `BiometricErasureRegister`.

```
rowHash = SHA-256( JSON canonique (RFC 8785) des colonnes de la ligne )
hash    = SHA-256( prevHash ‖ seq ‖ type ‖ entityId ‖ rowHash ‖ at )
```

Verrou consultatif sur la dernière ligne (comme `AuditLog`) ; `seq` sans trou ; aucune mise à jour ni suppression.

6.2 Trois niveaux de preuve hors de portée de l'exploitation

Niveau	Mécanisme	Cadence	Détecte
1	**Expédition de chaque `hash`** vers un journal externe à écriture seule	Temps réel	Toute altération, y compris dans la fenêtre entre deux points de contrôle
2	**Point de contrôle signé** (`seq`, `hash` de tête, date) par une **clé de signature du HSM**	15 minutes	Reconstruction de la chaîne par un administrateur sans accès au HSM
3	**Ancrage quotidien horodaté** par un tiers de confiance (RFC 3161)	Quotidien	Retour en arrière complet de la base et du journal local

Le même dispositif est appliqué à la tête de `AuditLog` (levée de la limite connue : suppression de la dernière ligne).

6.3 Vérification

Vérification quotidienne par l'**auditeur** et le **responsable de la protection des données**, indépendants de l'exploitation : chaîne

complète, signatures, concordance avec les empreintes externes et les ancrages. **Écart = incident critique** avec suspension de la bascule en production.

6.4 Colonnes immuables et contraintes (A-06, A-07)

Table	Règle
`BiometricSearch`	**Insertion seule pour les lignes réelles** ; pour les lignes `isDemo = vrai`, seules `action`, `actionNotes`, `actionById`, `actionAt` restent modifiables (comportement conservé) ; **`isDemo` immuable dans tous les cas** (déclencheur) ; `CHECK (isDemo = faux ⇒ requestedById, providerCode, subjectScope NON NULS)`
`BiometricMatch`	Insertion seule ; `subjectId` obligatoire, `personId` interdit pour les lignes réelles
`BiometricReview`	Insertion seule ; **une seule décision finale** par recherche (index unique partiel) ; `INCONCLUSIVE` suivie d'une seconde revue par une **autre identité** ; au-delà : escalade
`BiometricControl` (réel)	Insertion seule ; transitions dans `BiometricControlEvent` (insertion seule) ; champs `reviewed*` dérivés en lecture seule ; contrôles simulés inchangés
`BiometricLedger`, checkpoints, registre d'effacement	Insertion seule

Le déclencheur de `BiometricReview` impose **opérateur ≠ demandeur ≠ relecteur au niveau de l'identité d'agent** (chapitre 9) et enregistre la force d'authentification (`mfaVerifiedAt`).

6.5 Fiches des anomalies de l'étape 2

A-02 — Aucune chaîne de hachage sur les tables biométriques

Élément	Contenu
Anomalie initiale	Aucune chaîne de hachage sur les tables biométriques — gravité **Critique**, statut de la revue **NON VALIDÉ**
Correction précise	**Registre biométrique chaîné** (`BiometricLedger`) alimenté par des fonctions `SECURITY DEFINER` à chaque insertion de recherche, correspondance, revue, événement de contrôle et décision d'effacement : empreinte canonique de la ligne, chaînage (`hash = SHA-256(prevHash ‖ seq ‖ type ‖ id ‖ rowHash ‖ date)`), verrou consultatif comme pour `AuditLog`. **Points de contrôle signés** par une clé de signature du HSM toutes les 15 minutes ; **expédition en temps réel** de chaque empreinte vers un journal externe à écriture seule ; **ancrage quotidien** horodaté par un tiers de confiance (RFC 3161). Même mécanisme pour la tête de `AuditLog`. Vérification quotidienne par l'auditeur et le responsable de la protection des données.
Composants concernés	Nouvelles tables `BiometricLedger`, `BiometricLedgerCheckpoint` ; fonctions et déclencheurs ; service d'ancrage ; tâche de vérification ; `src/server/audit-chain.ts` (extension à l'ancrage) ; stockage externe à écriture seule
Risques résiduels	Compromission simultanée de la base, du HSM et du support externe ; fenêtre de 15 minutes couverte par l'expédition en temps réel mais non nulle
Validations nécessaires	Architecte sécurité externe (preuve de la chaîne et de l'ancrage) ; essai de falsification par une équipe indépendante ; Responsable indépendant de la protection des données (procédure de vérification)
Chapitre	6

A-03 — Empreinte de tête exportée sans destinataire ni mécanisme

Élément	Contenu
Anomalie initiale	Empreinte de tête exportée sans destinataire ni mécanisme — gravité **Majeure**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Support externe **à écriture seule dans un autre domaine d'administration** (stockage à verrouillage d'objet, ou serveur de journaux dédié hors du périmètre des administrateurs de la plate-forme) ; fréquence : temps réel (empreintes), 15 min (points de contrôle signés), quotidienne (ancrage horodaté) ; vérificateur : auditeur + responsable de la protection des données, indépendants de l'exploitation ; alerte immédiate en cas d'écart ; conservation ≥ 10 ans pour les ancrages.
Composants concernés	Service d'ancrage (nouveau), `deploy/*`, procédure d'exploitation
Risques résiduels	Dépendance au tiers d'horodatage ; coût du stockage externe
Validations nécessaires	Architecte sécurité externe ; Responsable indépendant de la protection des données
Chapitre	6

A-06 — Colonnes immuables non exhaustives ; `isDemo` modifiable ; demandeur facultatif

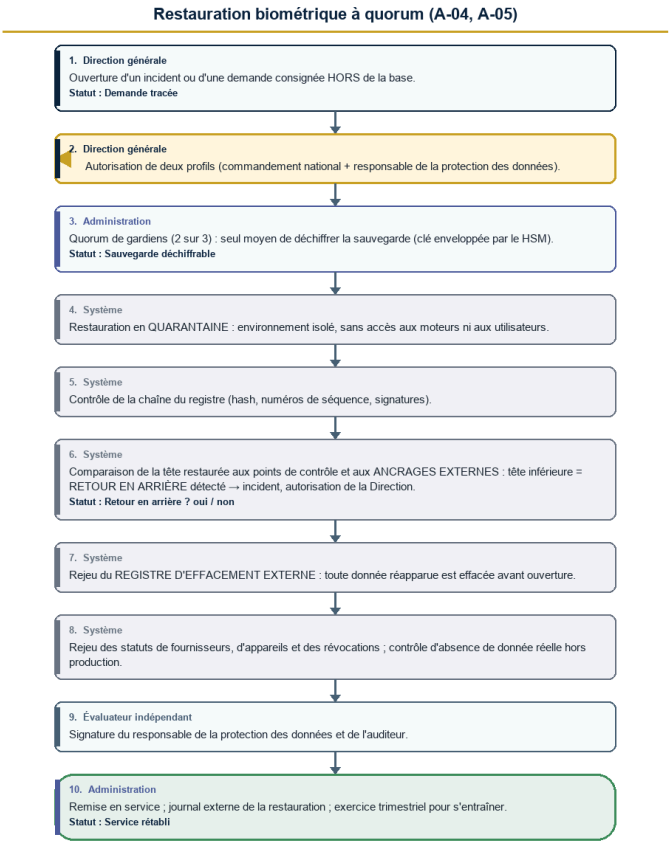
Élément	Contenu

Anomalie initiale	Colonnes immuables non exhaustives ; `isDemo` modifiable ; demandeur facultatif — gravité **Majeure**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Liste exhaustive : `BiometricSearch` — **aucune colonne modifiable pour les lignes réelles** (insertion seule) ; pour les lignes `isDemo = vrai` seules les colonnes historiques `action`, `actionNotes`, `actionById`, `actionAt` restent modifiables ; **`isDemo` est immuable dans tous les cas** (déclencheur). `BiometricMatch`, `BiometricReview`, `BiometricControlEvent`, `BiometricLedger` : insertion seule. Contraintes : `isDemo = faux ⇒ requestedById, providerCode, subjectScope NON NULS` ; une seule décision finale par recherche (index unique partiel).
Composants concernés	`prisma/schema.prisma` (migrations additives), déclencheurs, `biometric/service.ts`
Risques résiduels	Les anciennes lignes DEMO restent modifiables (comportement conservé volontairement)
Validations nécessaires	Architecte sécurité externe ; tests d'attaque (UPDATE de chaque colonne, bascule de `isDemo`)
Chapitre	6

A-07 — `BiometricControl` modifiable et deuxième source de décision

Élément	Contenu
Anomalie initiale	`BiometricControl` modifiable et deuxième source de décision — gravité **Majeure**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Pour les contrôles réels (`isSimulation = faux`) : ligne **insertion seule** ; transitions d'état dans `BiometricControlEvent` (insertion seule) ; décision humaine **uniquement** dans `BiometricReview` ; les champs `reviewed*` du contrôle deviennent dérivés en lecture seule. Les contrôles simulés gardent leur comportement actuel (inchangé).
Composants concernés	`biometric/control.ts`, `biometric/review.ts` (nouveau), `queries.ts`, écran de contrôle
Risques résiduels	Période de double lecture (anciens et nouveaux champs) jusqu'à la fin de la phase 6
Validations nécessaires	Architecte sécurité externe ; non-régression `tests/integration/biocontrol.test.ts`
Chapitre	6

7. Étape 3 — Sauvegardes, restauration et registre d'effacement (A-04, A-05, A-16)



7.1 Principes

Sujet	Règle
Séparation	**Base biométrique dédiée** ; la sauvegarde principale de l'application **exclut** le schéma biométrique (contrôle automatique)
Chiffrement	Sauvegarde biométrique chiffrée par une **clé de sauvegarde enveloppée par le HSM** ; déchiffrement **seulement avec le quorum de gardiens**
Rétention	**≤ 35 jours**, verrouillage d'objet ; clé de sauvegarde **détruite** à l'échéance
Restauration	**Jamais** par le droit `system:backup` ; procédure à quorum (7.2)
Registre d'effacement	**Répliqué en continu hors de la base**, entrées signées par le HSM, conservé **≥ 125 jours** (35 + 90 ; recommandation : 1 an)

7.2 Procédure de restauration (dix étapes)

1. Ouverture d'un **incident ou d'une demande** consignée (hors base).
2. **Autorisation** de deux profils (commandement national et responsable de la protection des données).
3. **Quorum de gardiens** (2 sur 3) pour déchiffrer la sauvegarde.
4. Restauration en **quarantaine** (environnement isolé, sans accès au moteur ni aux utilisateurs).
5. **Contrôle de la chaîne** du registre.
6. **Comparaison de la tête restaurée** aux points de contrôle et ancrages externes : tête inférieure = **retour en arrière détecté** → incident, autorisation de la Direction, journalisation.
7. **Rejeu du registre d'effacement externe** : toute donnée réapparue est effacée.
8. **Rejeu des statuts** de fournisseurs, d'appareils et de révocations.
9. Contrôle d'absence de donnée réelle hors production.
10. **Remise en service** après signature du responsable de la protection des données et de l'auditeur.

7.3 Exercices et indicateurs

Exercice **trimestriel** observé par l'auditeur ; objectifs indicatifs : RPO ≤ [24 h], RTO ≤ [4 h] ; test annuel de perte du quorum ; test de rétention (aucune sauvegarde biométrique > 35 jours).

7.4 Fiches des anomalies de l'étape 3

A-04 — La restauration d'une sauvegarde peut falsifier l'historique

Élément	Contenu
Anomalie initiale	La restauration d'une sauvegarde peut falsifier l'historique — gravité **Majeure**, statut de la revue **NON VALIDÉ**
Correction précise	Restauration biométrique **à double contrôle natif** : les sauvegardes sont chiffrées par une clé de sauvegarde **enveloppée par le HSM**, déchiffrable seulement avec le quorum de gardiens (2 sur 3). Restauration en **quarantaine** (environnement isolé) puis contrôles automatiques : chaîne valide ; **tête restaurée comparée aux ancrages externes** (tête inférieure = retour en arrière détecté, incident obligatoire, autorisation de la Direction) ; rejeu du registre d'effacement externe ; rejeu des statuts de fournisseurs et d'appareils ; absence de donnée réelle hors production. Exercice trimestriel. Le droit `system:backup` ne permet **pas** de restaurer la base biométrique.
Composants concernés	`deploy/backup/*`, procédure de restauration (nouvelle), service d'ancrage, HSM
Risques résiduels	Fenêtre de perte des données postérieures au point de restauration (inévitable) ; disponibilité du quorum de gardiens
Validations nécessaires	Architecte sécurité externe ; exercice de restauration observé par l'auditeur ; Responsable indépendant de la protection des données
Chapitre	7

A-05 — Registre d'effacement stocké dans la base restaurable

Élément	Contenu
Anomalie initiale	Registre d'effacement stocké dans la base restaurable — gravité **Majeure**, statut de la revue **NON VALIDÉ**
Correction précise	Registre d'effacement **répliqué en continu hors de la base** (journal externe à écriture seule, entrées signées par le HSM : identifiant, date, décision du responsable de la protection des données), conservé **au moins 125 jours** (35 jours de sauvegarde + 90 jours de marge ; recommandation : 1 an). **Vérification obligatoire avant toute remise en service** après restauration : toute donnée réapparue est effacée avant ouverture.

TECHNOTICHAD

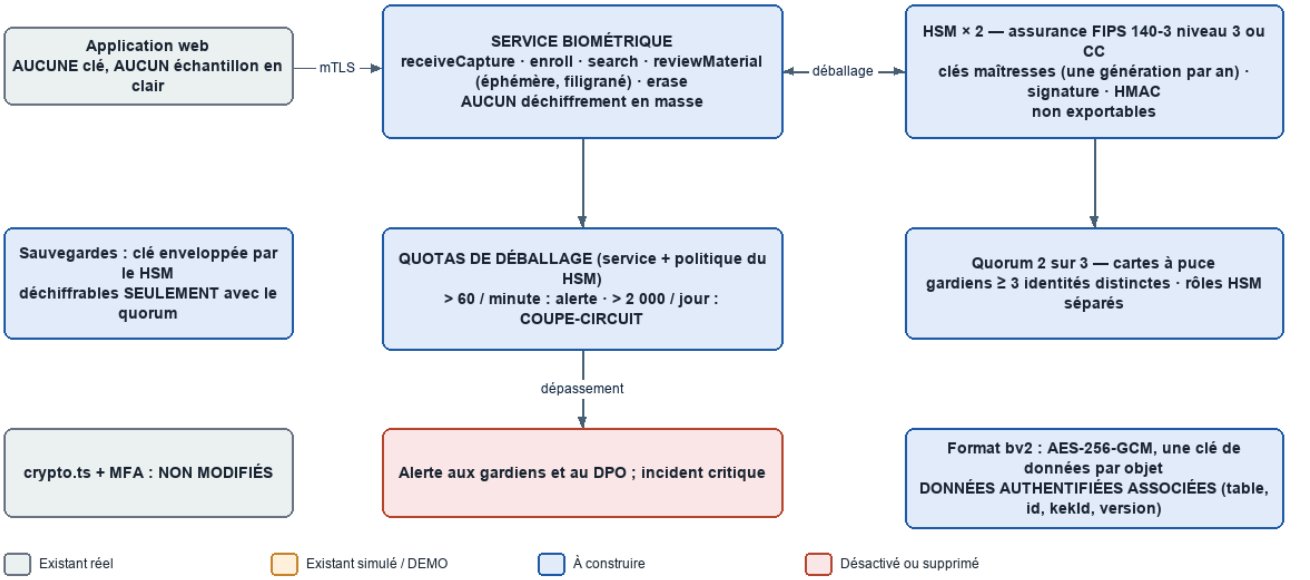
Composants concernés	`BiometricErasureRegister` (table + miroir externe), `biometric/retention.ts` (nouveau), procédure de restauration
Risques résiduels	Délai entre l'effacement et la réplication (fermé par la réplication synchrone du miroir)
Validations nécessaires	Architecte sécurité externe ; Responsable indépendant de la protection des données ; Juriste (valeur de la « mise hors d'usage » en sauvegarde)
Chapitre	7

A-16 — Sauvegarde globale incompatible avec la limite de 35 jours

Élément	Contenu
Anomalie initiale	Sauvegarde globale incompatible avec la limite de 35 jours — gravité **Moyenne**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	**Base biométrique dédiée** (cluster ou base distincte, rôle distinct) ; sauvegarde principale de l'application **exclut** le schéma biométrique ; sauvegarde biométrique séparée, verrouillage d'objet à 35 jours, clé de sauvegarde détruite à l'échéance ; contrôle automatique que la sauvegarde principale ne contient aucune table biométrique.
Composants concernés	`deploy/backup/*`, `deploy/docker-compose.yml`, configuration de la base biométrique
Risques résiduels	Deux cycles de sauvegarde à exploiter
Validations nécessaires	Architecte sécurité externe ; contrôle de l'auditeur
Chapitre	7

8. Étape 4 — Architecture du coffre de clés (A-11, A-12, A-13)

Service biométrique, HSM, quotas et quorum (A-11, A-12, A-13)



8.1 Service biométrique séparé

L'application web ne détient **aucune clé et aucun échantillon en clair**. Le service biométrique expose une API étroite : `receiveCapture`, `enroll`, `search`, `reviewMaterial` (rendu éphémère filigrané, lien signé ≤ 60 s, sans téléchargement), `erase`. **Aucun point ne déchiffre ou n'exporte en masse.** Le service s'authentifie auprès du HSM par une identité dédiée.

8.2 HSM

Sujet	Exigence
Matériel	**Deux HSM** synchronisés, sur deux sites ; assurance **FIPS 140-3 niveau 3** ou Critères Communs (D-21)
Rôles HSM	**Officier de sécurité**, **officier de chiffrement**, **auditeur**, tenus par des personnes différentes
Quorum	**2 sur 3** au minimum (cartes à puce) pour : générer ou détruire une clé maîtresse, déchiffrer les sauvegardes, administrer le HSM
Clés	Maîtresses (une génération par année), de signature (registre, effacement), de pseudonymes (HMAC) : **non exportables**
Contrôle	Les approbations applicatives sont un **complément**, jamais le seul contrôle

8.3 Quotas de déballage et coupe-circuit (valeurs initiales, à calibrer en phase 3)

Seuil	Action
> 60 déballages par minute	Ralentissement et alerte aux gardiens et au responsable de la protection des données
> 2 000 déballages par jour	**Coupe-circuit** : déballage suspendu, incident critique
Déballage hors recherche, revue ou inscription en cours	Refus et alerte

8.4 Format de chiffrement `bv2` et données authentifiées associées

`bv2.<kekId>.<DEK enveloppée>.<iv>.<tag>.<chiffré>` (AES-256-GCM ; IV de 96 bits aléatoire ; **une clé de données par objet**). Les **données authentifiées associées** sont `bv2 | kekId | table | identifiant de l'enregistrement | version | finalité` : un chiffré **ne peut pas être substitué** à un autre enregistrement ou rejoué. `crypto.ts` et l'authentification à deux facteurs ne sont **pas** modifiés.

8.5 Cycle de vie des clés

État	Description
Générée	Créée dans le HSM par cérémonie à quorum ; non active
Active	Enveloppe les nouvelles clés de données (une génération par an)
Désactivée	Ne sert plus qu'à déballer ; ré-enveloppement en cours
Détruite	Après ré-enveloppement **complet** et **expiration des sauvegardes** qui la référencent
Compromise	Voir 8.6

8.6 Procédures

Événement	Procédure
Compromission d'une clé maîtresse	(1) déclarer l'incident, (2) couper le déballage, (3) générer une génération de remplacement par cérémonie, (4) ré-envelopper toutes les clés de données (lot supervisé, débit limité), (5) détruire la génération compromise **après vérification**, (6) évaluer l'exposition et notifier (D-15)
Panne d'un HSM	Bascule sur le second ; remplacement et resynchronisation par cérémonie ; test annuel
Migration d'un HSM à un autre fournisseur	Ré-enveloppement des clés de données (ancien HSM déballe, nouveau enveloppe) dans les quotas ; double fonctionnement ; destruction de l'ancien
Départ d'un gardien	Révocation de sa carte, ré-émission, re-clé du quorum ; au moins 3 titulaires en permanence
Séquestre	Sauvegarde chiffrée native du HSM, conservée sous scellés dans un lieu distinct ; test annuel de restauration
Agilité cryptographique	Version de format et registre d'algorithmes ; revue tous les trois ans ; migration planifiée

8.7 Fiches des anomalies de l'étape 4

A-11 — Coffre dans le processus applicatif (oracle de déballage)

Élément	Contenu
Anomalie initiale	Coffre dans le processus applicatif (oracle de déballage) — gravité **Majeure**, statut de la revue **NON VALIDÉ**
Correction précise	**Service biométrique séparé** (processus, identité, hôte et réseau distincts) : l'application web n'a jamais accès aux clés ni aux échantillons en clair ; API étroite (recevoir une capture, inscrire, rechercher, matériel de revue éphémère, effacer) **sans point de déchiffrement en masse**. **Quotas de déballage** appliqués par le service et par une politique du HSM (par minute et par jour) ; **coupe-circuit** automatique avec alerte aux gardiens et au responsable de la protection des données ; journalisation côté HSM.
Composants concernés	Nouveau service biométrique, `biometric/vault.ts` (déplacé dans le service), `src/server/biometric/service.ts` (client), `deploy/*`
Risques résiduels	Compromission du service biométrique lui-même (surface réduite, quotas limitant l'exfiltration)
Validations nécessaires	Architecte sécurité externe ; test d'intrusion visant l'exfiltration massive
Chapitre	8

A-12 — Double contrôle des clés défini dans l'application

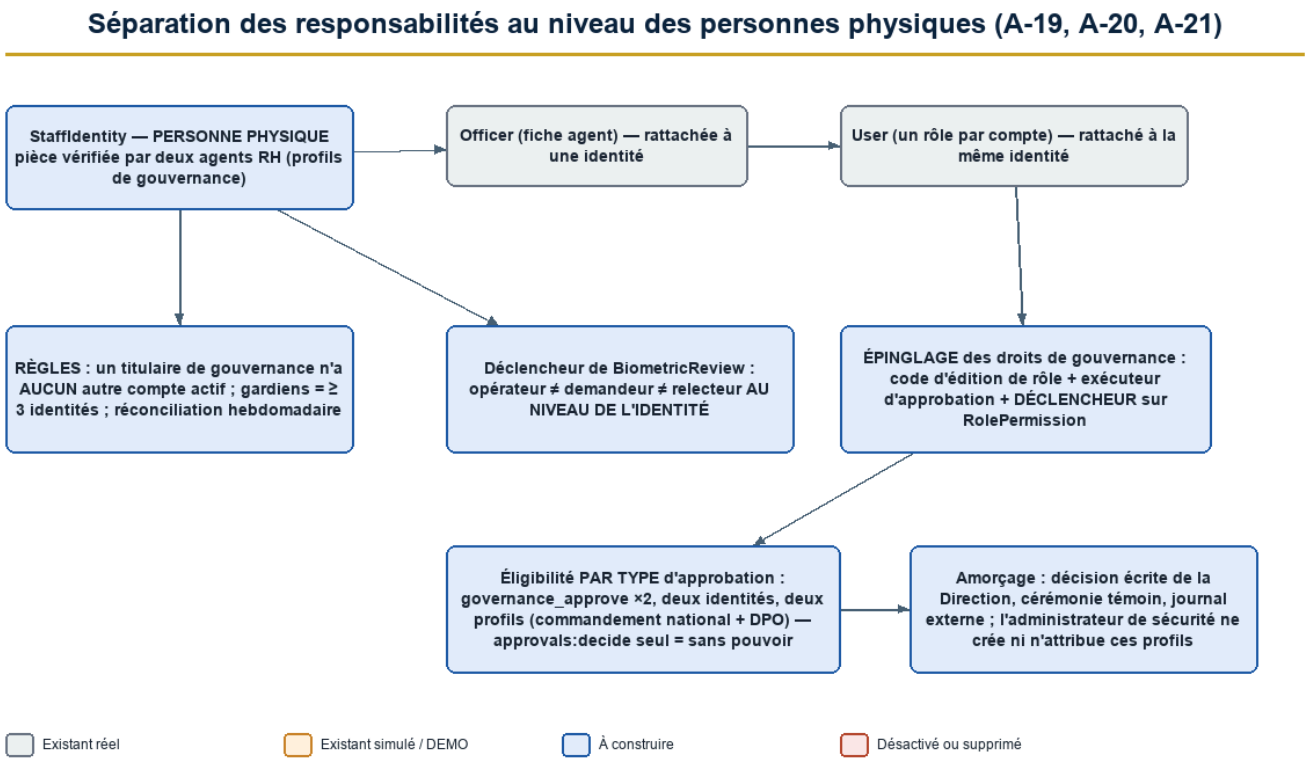
Élément	Contenu
Anomalie initiale	Double contrôle des clés défini dans l'application — gravité **Majeure**, statut de la revue **VALIDÉ SOUS RÉSERVE**

Correction précise	**Quorum natif du HSM** (carte à puce, 2 sur 3 au minimum) pour générer, détruire une clé maîtresse et déchiffrer les sauvegardes ; **rôles HSM séparés** (officier de sécurité, officier de chiffrement, auditeur) tenus par des personnes différentes ; deux HSM synchronisés ; niveau d'assurance exigé (D-21). Les approbations applicatives restent un **complément**, jamais le seul contrôle.
Composants concernés	HSM (nouveau), service de clés, procédure de cérémonie
Risques résiduels	Perte simultanée de gardiens (≥ 3 titulaires, séquestre)
Validations nécessaires	Architecte sécurité externe ; audit de la cérémonie ; D-21
Chapitre	8

A-13 — Cycle de vie des clés incomplet ; absence de données authentifiées associées

Élément	Contenu
Anomalie initiale	Cycle de vie des clés incomplet ; absence de données authentifiées associées — gravité **Moyenne**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Chapitre complet (états, rotation, **compromission**, panne et remplacement du HSM, séquestre, départ d'un gardien, agilité cryptographique). Format `bv2` : le chiffrement lie le chiffré à l'identifiant de la table, de l'enregistrement, au `kekId` et à la version (**données authentifiées associées**), ce qui interdit la substitution entre lignes. Ré-enveloppement en deux temps avec retour possible.
Composants concernés	`biometric/vault.ts`, `key-service.ts`, procédures
Risques résiduels	Erreur humaine en cérémonie (exercices annuels)
Validations nécessaires	Architecte sécurité externe ; exercice de compromission simulée
Chapitre	8

9. Étape 5 — Séparation des responsabilités au niveau des personnes physiques (A-19, A-20, A-21, A-22)



9.1 Identité d'agent

`StaffIdentity(id, documentType, documentDigest, verifiedBy, verifiedAt, status)` : une **personne physique** (pièce vérifiée, résumé à clé du numéro). Chaque fiche agent (`Officer`) et chaque compte (`User`) se rattachent à **une** identité. Règles :

1. Un titulaire de **profil de gouvernance** n'a **aucun autre compte actif** (contrainte et réconciliation hebdomadaire).

2. Les **gardiens de clés** sont au moins **trois identités distinctes**.
3. La revue vérifie **opérateur ≠ demandeur ≠ relecteur au niveau de l'identité**.
4. L'identité d'un titulaire de gouvernance est vérifiée **par deux agents des ressources humaines distincts** (droit existant `hr:manage`).

9.2 Épinglage des droits de gouvernance

Droit	Attribuable seulement à
`biometric:provider_manage`, `device_manage`, `export_portability`	`BIOMETRIC_PLATFORM_ADMIN`
`biometric:key_manage`	`KEY_CUSTODIAN`
`biometric:retention_manage`, `erasure_decide`	`DATA_PROTECTION_OFFICER`
`biometric:history_view_candidates`	`DATA_PROTECTION_OFFICER`, `AUDITOR`
`biometric:governance_approve`	`NATIONAL_COMMANDER`, `DATA_PROTECTION_OFFICER`
`biometric:enroll_validate`, `watchlist_review`	`BIOMETRIC_OFFICER`

Contrôle **à trois niveaux** : code d'édition de rôle, exécuteur d'approbation, **déclencheur de base** sur `RolePermission` ; test automatisé.

9.3 Éligibilité d'approbation par type

Type d'approbation	Conditions
Activation d'un fournisseur	`governance_approve` ×2, **deux identités et deux profils distincts** (commandement national + responsable de la protection des données)
Rotation ou destruction de clé	idem + quorum du HSM
Export de portabilité	idem + gardiens
Attribution d'un profil de gouvernance	idem ; **l'administrateur de sécurité ne peut ni créer ni attribuer** ces profils

Les titulaires de `approvals:decide` **seuls** n'ont aucun pouvoir sur ces types.

9.4 Amorçage

Premier responsable de la protection des données et premiers gardiens désignés par **décision écrite de la Direction** lors d'une **cérémonie témoin** (deux témoins, procès-verbal, journal externe). La décision d'amorçage est conservée hors de la base.

9.5 Droits existants et rôles (A-22)

Aucun des 29 rôles ne perd un droit ; aucun des 158 droits n'est renommé ni supprimé. **Tests à adapter** : sensibilité, libellés FR/AR, matrice de routes, décomptes de documentation. La réponse de l'historique porte un champ `visibility`.

9.6 Fiches des anomalies de l'étape 5

A-19 — Séparation au niveau du compte et non de la personne

Élément	Contenu
Anomalie initiale	Séparation au niveau du compte et non de la personne — gravité **Majeure**, statut de la revue **NON VALIDÉ**
Correction précise	**Identité d'agent** (`StaffIdentity`) vérifiée sur pièce, unique par personne physique, rattachée à la fiche agent et au compte. Règles : un titulaire de profil de gouvernance **n'a aucun autre compte actif** ; deux gardiens = deux identités distinctes ; la revue vérifie **opérateur ≠ demandeur ≠ relecteur au niveau de l'identité** ; contrôle à l'attribution, à chaque connexion d'un compte de gouvernance et par réconciliation hebdomadaire.
Composants concernés	Nouvelle table `StaffIdentity`, `Officer`, `User` (liaison), `admin/users.ts`, `approvals/*`, `biometric/review.ts`
Risques résiduels	Pièce d'identité falsifiée ou complicité à l'enregistrement
Validations nécessaires	Architecte sécurité externe ; Responsable indépendant de la protection des données ; Direction (D-04)
Chapitre	9

A-20 — Pas d'épinglage des droits de gouvernance ; éligibilité d'approbation trop large

Élément	Contenu
Anomalie initiale	Pas d'épinglage des droits de gouvernance ; éligibilité d'approbation trop large — gravité **Majeure**, statut de la revue **NON VALIDÉ**

Correction précise	**Épinglage** : chaque droit de gouvernance n'est attribuable qu'à son profil (contrôle dans le code d'édition de rôles et dans l'exécuteur d'approbation, **et déclencheur de base** sur `RolePermission`) ; matrice d'éligibilité **par type d'approbation** : les nouveaux types exigent `biometric:governance_approve` de deux identités et de deux profils distincts ; les titulaires de `approvals:decide` seuls n'ont aucun pouvoir sur eux ; test automatisé.
Composants concernés	`rbac/permissions.ts`, `roles.ts`, `grants.ts`, `admin/roles.ts`, `approvals/rules.ts` et `service.ts`, déclencheur sur `RolePermission`
Risques résiduels	Modification du code par un développeur (contrôle de version et revue)
Validations nécessaires	Architecte sécurité externe ; revue du code d'approbation
Chapitre	9

A-21 — Attribution des profils de gouvernance par l'administrateur de sécurité

Élément	Contenu
Anomalie initiale	Attribution des profils de gouvernance par l'administrateur de sécurité — gravité **Moyenne**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Attribution **uniquement** par une demande approuvée par le commandement national et le responsable de la protection des données ; **l'administrateur de sécurité ne peut ni créer ni attribuer** ces profils ; premier titulaire désigné par **décision écrite de la Direction** lors d'une cérémonie d'amorçage témoin et journalisée.
Composants concernés	`rbac/grants.ts`, `approvals/*`, procédure d'amorçage (nouvelle)
Risques résiduels	Amorçage fondé sur la confiance en la décision écrite
Validations nécessaires	Direction ; Responsable indépendant de la protection des données
Chapitre	9

A-22 — Tests à contenu exact et contrat de réponse de l'historique

Élément	Contenu
Anomalie initiale	Tests à contenu exact et contrat de réponse de l'historique — gravité **Moyenne**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Liste des tests à adapter (sensibilité, libellés FR/AR, matrice de routes, décomptes de documentation) ; la réponse de l'historique porte un champ `visibility` explicite (`FULL` pour les lignes DEMO, `METADATA` ou `FULL` selon le profil pour les lignes réelles) ; test de contrat versionné.
Composants concernés	`tests/unit/sensitivity.test.ts`, `tests/security/route-matrix.test.ts`, `biometric/queries.ts`, i18n
Risques résiduels	Oubli d'un test lors de l'implémentation (liste de contrôle)
Validations nécessaires	Architecte sécurité externe ; revue de la liste de tests
Chapitre	9

10. Étape 6 — Bases légales multiples et précédence preuve / effacement (A-14, A-15)

10.1 Bases légales multiples

`BiometricSampleBasis(sampleId, caseId ou décision, start, end, status)`. **Échéance = maximum des bases actives.** Événements de conservation : statut de partie (`CLEARED`, `CHARGED`…), issue d'affaire (`UNFOUNDED`, `DISMISSED`…), décès, décision de justice, demande de la personne. **Effacement seulement lorsque plus aucune base n'est active.**

Situation	Résultat
Hors de cause dans l'affaire A, partie active dans l'affaire B	Conservation (base B active)
Hors de cause partout	Effacement sous 30 jours (délai à confirmer)
Personne décédée	Échéance déclenchée ; recherche refusée

10.2 Précédence entre preuve et effacement (A-15, D-06)

Objet	Règle proposée

Copie probatoire (pièce avec chaîne de possession)	**Conservée** tant que l'affaire est ouverte (décision du magistrat) ; hors de la galerie
Échantillon de référence opérationnel	Effacé selon la politique et le registre d'effacement
Copies	**Inventoriées** et rattachées au registre ; effacées conjointement quand l'autorisation judiciaire le permet

10.3 Fiches des anomalies de l'étape 6

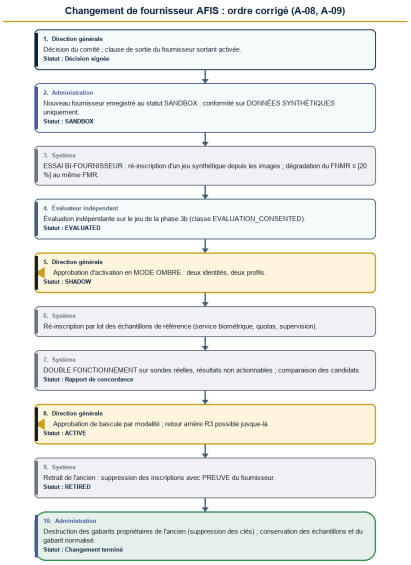
A-14 — Conservation sans bases légales multiples

Élément	Contenu
Anomalie initiale	Conservation sans bases légales multiples — gravité **Moyenne**, statut de la revue **NON VALIDÉ**
Correction précise	Table `BiometricSampleBasis` (échantillon ↔ affaire ou décision, début, fin) ; **échéance = maximum des bases actives** ; les événements de conservation sont émis par les statuts de partie (`CLEARED`, `CHARGED`…) et les issues d'affaire ; effacement **seulement** quand plus aucune base n'est active ; calcul documenté et testé.
Composants concernés	Nouvelles tables, `cases/service.ts`, `persons/service.ts` (émission d'événements), `biometric/retention.ts`
Risques résiduels	Qualification juridique des bases (à confirmer)
Validations nécessaires	Juriste ; Responsable indépendant de la protection des données
Chapitre	10

A-15 — Conflit entre effacement et conservation de preuve

Élément	Contenu
Anomalie initiale	Conflit entre effacement et conservation de preuve — gravité **Moyenne**, statut de la revue **DÉCISION REQUISE**
Correction précise	Règle de précédence proposée : **la conservation de preuve judiciaire l'emporte** tant que l'affaire est ouverte, mais ne porte que sur la **copie probatoire** (pièce avec chaîne de possession) ; l'échantillon de référence opérationnel est effacé selon la politique ; toutes les copies sont inventoriées et rattachées au registre d'effacement ; décision du magistrat en cas de doute. À valider avec la Justice (D-06).
Composants concernés	`evidence/service.ts`, `retention.ts`, registre d'effacement
Risques résiduels	Désaccord d'interprétation juridique
Validations nécessaires	Juriste ; Responsable indépendant de la protection des données ; Justice
Chapitre	10

11. Étape 7 — Portabilité AFIS et interdiction des essais prématurés (A-08, A-09)



11.1 Classes de données et statuts de fournisseur

Statut du fournisseur	Classes de données admises	Sondes réelles
`REGISTERED`	Aucune	Interdites
`SANDBOX`	`SYNTHETIC`, `LICENSED_RESEARCH`	**Interdites**
`EVALUATED`	+ `EVALUATION_CONSENTED` (sous protocole)	**Interdites**
`SHADOW`	+ `OPERATIONAL`	**Oui, non actionnables**
`ACTIVE`	`OPERATIONAL`	Oui
`SUSPENDED`, `RETIRED`	Aucune	Interdites

Chaque échantillon et chaque sonde portent une **classe de données**. L'orchestrateur **et un déclencheur de base** refusent d'associer une classe à un fournisseur dont le statut ne l'admet pas. Les moteurs sont dans une zone réseau **sans sortie** ; l'instance `SANDBOX` est **isolée** de toute galerie opérationnelle et de toute clé de production.

11.2 Procédure de changement de fournisseur (ordre corrigé)

1. Décision du comité ; clause de sortie du fournisseur sortant activée.
2. Nouveau fournisseur enregistré (`SANDBOX`) : conformité sur **données synthétiques**.
3. **Essai bi-fournisseur** : ré-inscription du jeu synthétique depuis les images ; écart de précision mesuré.
4. **Évaluation indépendante** (classe `EVALUATION_CONSENTED`, protocole de la phase 3b) → statut `EVALUATED`.
5. **Approbation d'activation en mode ombre** (deux identités, deux profils) → statut `SHADOW`.
6. **Ré-inscription par lot** des échantillons de référence (service biométrique, quotas, supervision).
7. **Double fonctionnement** sur sondes réelles, résultats non actionnables.
8. **Approbation de bascule** par modalité → `ACTIVE`.
9. Retrait de l'ancien avec **preuve de suppression** ; statut `RETIRED`.
10. Destruction des gabarits propriétaires de l'ancien (suppression des clés) ; conservation des échantillons et du gabarit normalisé.

Retour arrière (classe R3) : tant que l'étape 8 n'est pas validée, l'ancien reste `ACTIVE`.

11.3 Essai bi-fournisseur et portabilité éprouvée

Critère de la phase 3 : ré-inscription d'un jeu synthétique ou sous licence de l'AFIS A vers l'AFIS B **depuis les images** ; **dégradation relative du FNMR ≤ [20 %] au même FMR** ; résultat de l'échange de gabarits normalisés documenté. Le **cahier des charges impose au soumissionnaire un bac à sable** pour cet essai ; **exercice annuel réel** ensuite.

11.4 Fiches des anomalies de l'étape 7

A-08 — Double fonctionnement sur données réelles avant évaluation

Élément	Contenu
Anomalie initiale	Double fonctionnement sur données réelles avant évaluation — gravité **Majeure**, statut de la revue **NON VALIDÉ**
Correction précise	Procédure réordonnée : conformité (données synthétiques) → **évaluation indépendante** → **approbation en mode ombre** → ré-inscription par lot → double fonctionnement → approbation de bascule. Garde **technique** : chaque échantillon porte une **classe de données** (`SYNTHETIC`, `LICENSED_RESEARCH`, `EVALUATION_CONSENTED`, `OPERATIONAL`) ; un fournisseur n'accepte que les classes autorisées par son **statut** (`SANDBOX` → synthétiques et sous licence ; `EVALUATED` → + évaluation sous protocole ; `SHADOW` → + opérationnel non actionnable ; `ACTIVE` → opérationnel) ; refus par le service **et par la base**.
Composants concernés	`BiometricProvider`, `BiometricSample`, `BiometricEnrollment`, `BiometricJob`, orchestrateur, déclencheurs
Risques résiduels	Erreur d'étiquetage de la classe de données (contrôles automatiques et audit)
Validations nécessaires	Architecte sécurité externe ; Juriste ; Responsable indépendant de la protection des données
Chapitre	11

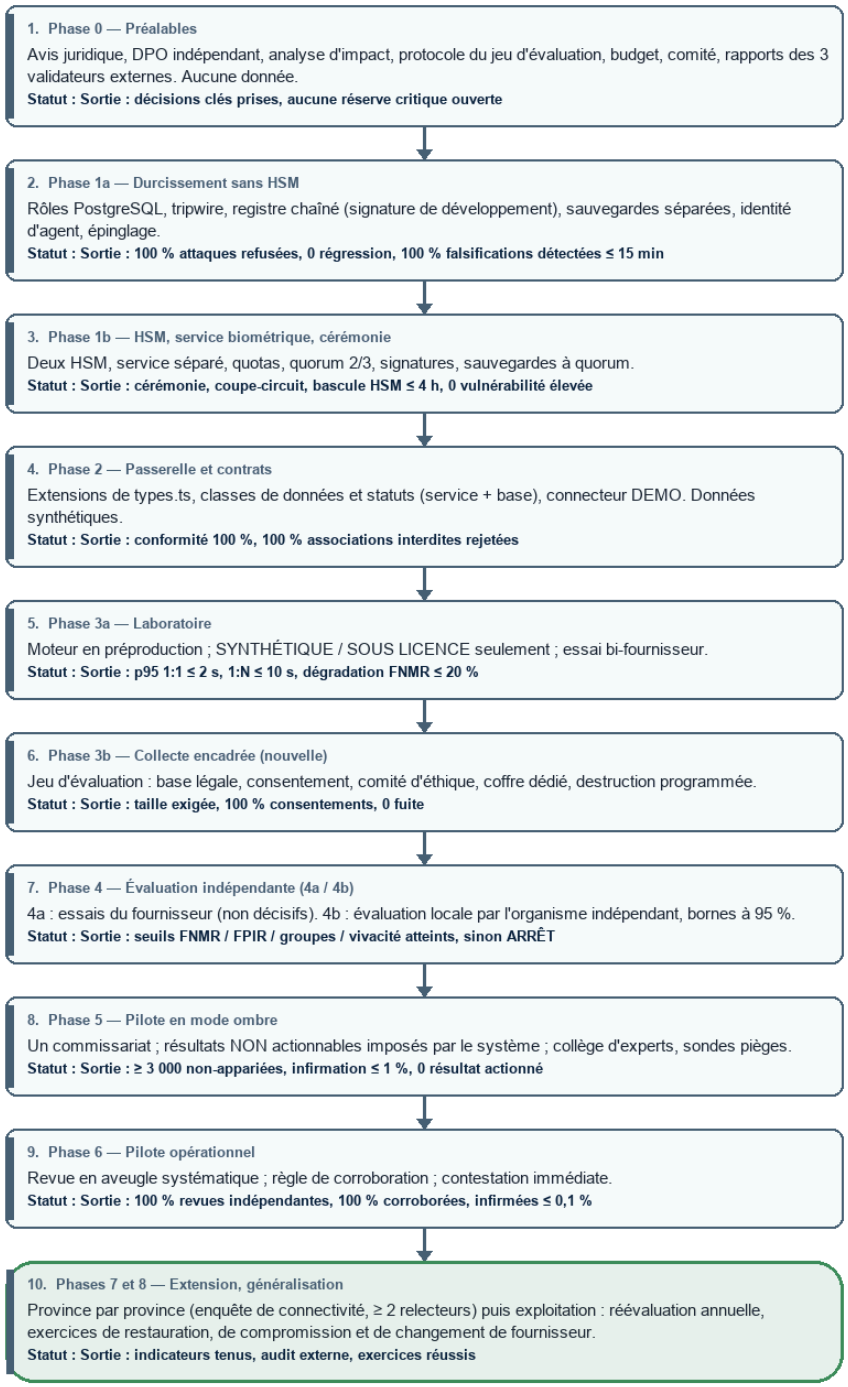
A-09 — Portabilité éprouvée seulement entre simulateurs

Élément	Contenu
Anomalie initiale	Portabilité éprouvée seulement entre simulateurs — gravité **Majeure**, statut de la revue **VALIDÉ SOUS RÉSERVE**

Correction précise	**Essai bi-fournisseur** en phase 3 : ré-inscription d'un jeu synthétique ou sous licence de l'AFIS A vers l'AFIS B depuis les images, et mesure de l'écart de précision (critère : dégradation relative du FNMR ≤ [20 %] au même FMR) ; test d'échange de gabarits normalisés documenté ; clause du marché imposant au soumissionnaire de fournir un bac à sable pour cet essai ; exercice annuel réel ensuite.
Composants concernés	Plan de tests, cahier des charges, outil de ré-inscription
Risques résiduels	Perte de précision inévitable sur gabarit normalisé (l'image est la voie de référence)
Validations nécessaires	Évaluateur indépendant ; Architecte sécurité externe
Chapitre	11

12. Étape 8 — Les neuf phases : critères mesurables, collecte encadrée, retour arrière (A-23, A-24, A-25, A-26)

Neuf phases v1.2 — portes mesurables (phases 1, 3 et 4 en sous-étapes)



12.1 Principes de mesure

Principe	Application
Vérité terrain	Jeu étiqueté (évaluation) ; **contre-expertise d'un échantillon aléatoire** par un collège d'experts indépendant (opération) ; **sondes pièges**
Bornes de confiance à 95 %	**Règle des trois** : zéro événement sur n essais indépendants borne le taux à **3/n**
Tailles minimales	Pour borner un taux d'erreur à 0,1 % : **≥ 3 000** essais non-appariés ; à 0,5 % : ≥ 600 ; à 1 % : ≥ 300 (évaluateur : bornes exactes)
Mesure humaine	Sensibilité et spécificité sur sondes pièges ; taux d'infirmation par le collège

Les valeurs entre crochets sont des **propositions** à fixer par la Direction et l'évaluateur (D-10).

12.2 Classes de retour arrière

Classe	Définition
R0	Drapeau ou configuration
R1	Version logicielle précédente, compatible avec les données
R2	Restauration (double contrôle, chapitre 7)
R3	Bascule de fournisseur (chapitre 11)
R4	Ré-enveloppement en deux temps : l'ancienne génération de clé reste **active** jusqu'à vérification

Avancer seulement : les valeurs d'énumération ajoutées sont inertes et conservées ; aucune table contenant des données réelles n'est supprimée avant l'échéance de conservation ; on **désactive** plutôt que de supprimer.

12.3 Phase 0 — Préalables

Rubrique	Contenu
Entrée	Mandat de la Direction ; comité nommé, **indépendant de l'éditeur et du fournisseur** (D-16)
Livrables	Avis juridique ; autorité de contrôle ; **responsable de la protection des données indépendant (D-20)** ; analyse d'impact ; **protocole du jeu d'évaluation** ; budget (D-13, D-21) ; appel d'offres ; **rapports des trois validateurs externes** ; décisions D-01, D-03, D-04, D-07, D-16, D-17, D-18, D-19, D-20, D-21, D-23
Sortie mesurable	Décisions listées **prises** ; avis juridique signé ; **aucune réserve critique ouverte** dans les trois rapports externes ; budget approuvé
Arrêt	Avis juridique défavorable (R-09)
Retour arrière	Sans objet (R0)
Données	**Aucune**

12.4 Phase 1a — Durcissement sans HSM

Rubrique	Contenu
Entrée	Phase 0 close
Livrables	Rôles PostgreSQL et tripwire ; déclencheurs et contraintes ; registre chaîné avec **signature de développement** ; journal externe de test ; séparation des sauvegardes ; identité d'agent et épinglage ; nouveaux types d'approbation
Sortie mesurable	**100 % des tests d'attaque refusés (42501)** ; **tripwire** : démarrage refusé avec un rôle excessif ; **toutes les suites existantes vertes** (0 régression ; MFA et séparation des administrateurs incluses) ; registre : **10 000 événements synthétiques** vérifiés, **100 %** des falsifications injectées détectées en **≤ 15 min** ; sauvegarde principale **sans** table biométrique ; restauration d'essai réussie ; 0 donnée biométrique réelle (analyse automatique)
Arrêt	Régression MFA ; échec d'une attaque simulée
Retour arrière	R1
Données	Démonstration et synthétiques

12.5 Phase 1b — HSM, service biométrique et cérémonie

Rubrique	Contenu
Entrée	1a close ; **deux HSM livrés** (D-13, D-21) ; ≥ 3 gardiens désignés
Livrables	Service biométrique séparé ; quotas ; cérémonie de clés ; signatures du registre par le HSM ; sauvegardes à quorum ; ancrage horodaté

Sortie mesurable	Cérémonie à **quorum 2 sur 3** réalisée ; **quotas** : alerte et coupe-circuit déclenchés aux seuils ; déballage impossible sans quorum pour les sauvegardes ; **bascule HSM ≤ [4 h]** ; compromission simulée (R4) réussie ; **0 vulnérabilité critique ou élevée** (test d'intrusion visant l'exfiltration massive)
Arrêt	Échec du quorum ou du coupe-circuit
Retour arrière	R4
Données	Synthétiques

12.6 Phase 2 — Passerelle et contrats

Rubrique	Contenu
Livrables	Extensions de `types.ts` ; simulateur DEMO ; conformité ; classes de données et statuts (service et base) ; sujets et liens ; connecteur DEMO
Sortie mesurable	Conformité **100 %** (simulateur et bac à sable, données synthétiques) ; **100 % des tentatives d'association d'une classe non admise rejetées** (service et base) ; contrats des routes existantes inchangés (tests de contrat à 100 %) ; matrice de routes de sécurité étendue
Arrêt	Le fournisseur refuse les clauses de portabilité ou de sortie
Retour arrière	R0 / R1
Données	Synthétiques

12.7 Phase 3a — Laboratoire (données synthétiques et sous licence)

Rubrique	Contenu
Entrée	Phase 2 close ; analyse d'impact validée
Sortie mesurable	1:1 **p95 ≤ [2 s]** (≥ 1 000 appels) ; 1:N **p95 ≤ [10 s]** à la taille cible ; disponibilité **≥ [99,5 %] sur 14 jours** ; erreurs techniques **< [0,5 %]** ; **0 donnée biométrique** dans les journaux (analyse automatique) ; **essai bi-fournisseur : dégradation du FNMR ≤ [20 %]** ; quotas calibrés ; test d'intrusion sans point élevé
Arrêt	Performances hors seuil après deux réglages
Retour arrière	R3
Données	**Synthétiques et sous licence uniquement** (aucun volontaire)

12.8 Phase 3b — Collecte encadrée du jeu d'évaluation (nouvelle)

Rubrique	Contenu
Entrée	**D-01** (base légale), **D-17** (mineurs), analyse d'impact, responsable de la protection des données, **comité d'éthique**, **1b close** (coffre dédié, HSM), protocole de la phase 0
Livrables	Registre de consentements ; coffre dédié (classe `EVALUATION_CONSENTED`) ; plan de **destruction** du jeu après l'évaluation
Sortie mesurable	Jeu conforme à la **taille exigée par l'évaluateur** (ordre de grandeur : ≥ [1 000] personnes) ; **100 %** des échantillons rattachés à un consentement ; **0 fuite** (audit) ; jeu **isolé** de toute galerie opérationnelle
Arrêt	Un consentement manquant ; une fuite
Retour arrière	R0 : effacement du jeu
Données	Personnes réelles consentantes

12.9 Phase 4 — Évaluation indépendante (4a / 4b)

Rubrique	Contenu
4a	Essais du fournisseur sur jeux sous licence (prérequis, **non décisifs**)
4b	**Évaluation locale** par l'organisme indépendant sur le jeu de la phase 3b
Sortie mesurable (indicatif, bornes à 95 %)	Empreintes : **FNMR ≤ [1 %] à FMR = [0,1 %]** ; identification au rang 1 **≥ [98 %]** avec FPIR **≤ [0,1 %]** ; échec d'acquisition **≤ [2 %]**. Visage : FNMR **≤ [3 %]** à FMR = [0,1 %] ; **rapport FNMR maximal / minimal entre groupes ≤ [1,5]**. Vivacité : **APCER ≤ [5 %]**, **BPCER ≤ [5 %]**
Arrêt	**Toute mesure hors seuil** : arrêt ou changement de fournisseur
Retour arrière	R3 ; effacement du jeu selon le protocole
Données	Jeu d'évaluation légalement constitué

12.10 Phase 5 — Pilote en mode « ombre »

Rubrique	Contenu
Entrée	4b conforme ; fournisseur `SHADOW` (approbation) ; personnes informées (D-14) ; relecteurs désignés ; **résultats non actionnables imposés par le système** (aucune notification, aucun lien, aucune suite)
Périmètre	Un commissariat
Sortie mesurable	Durée **≥ [8 semaines]** ; **≥ [3 000] recherches non-appariées** (taux d'erreur borné à 0,1 %) ; **collège d'experts** : taux d'infirmation des résultats « à revoir » **≤ [1 %]** sur un échantillon aléatoire de **≥ [5 %]** ; **sondes pièges** : sensibilité des relecteurs **≥ [95 %]**, spécificité **≥ [98 %]** ; revue **≤ [24 h]** pour **≥ [95 %]** ; **0 résultat actionné** (audit) ; **0 incident de sécurité élevé** ; 100 % des alertes d'anomalie traitées
Arrêt	Incident élevé ; résultat actionné par erreur
Retour arrière	R0 : fournisseur `SUSPENDED` ; données conservées chiffrées
Données	Réelles, base légale

12.11 Phase 6 — Pilote opérationnel limité

Rubrique	Contenu
Entrée	Phase 5 conforme ; **règle de corroboration** adoptée (D-19) ; fournisseur `ACTIVE` par approbation
Sortie mesurable	**100 %** des décisions issues d'une **revue indépendante en aveugle** ; **100 %** des mesures coercitives **corroborées** par un élément non biométrique ; décisions **infirmées** (contestation ou collège) **≤ [0,1 %]** des actions ; revue **≤ [24 h]** pour **≥ [95 %]** ; 0 incident élevé sur **[8 semaines]** ; erreurs signalées traitées sous **[7 jours]**
Arrêt	Atteinte aux droits avérée ; incident élevé
Retour arrière	R0 (retour en mode ombre)
Données	Réelles

12.12 Phase 7 — Extension provinciale

Rubrique	Contenu
Entrée	Phase 6 conforme ; **enquête de connectivité** (D-23) ; politique hors ligne arrêtée (D-08) ; **≥ [2] relecteurs par province**
Sortie mesurable (par province)	**100 %** des appareils inscrits et signés ; **≥ [95 %]** des utilisateurs formés et évalués ; indicateurs de la phase 6 tenus **[4 semaines]** ; **audit externe** sans point critique
Arrêt	Réservoir de relecteurs insuffisant
Retour arrière	R0 : province retirée du périmètre

12.13 Phase 8 — Généralisation

Rubrique	Contenu
Sortie mesurable (continue)	**Réévaluation annuelle** (précision, écarts de groupes, vivacité) ; **exercice annuel réel de changement de fournisseur** ; **exercice trimestriel de restauration** ; exercice annuel de compromission de clé ; revue annuelle des anomalies et de la qualité de la revue humaine
Arrêt	Perte de conformité ; fournisseur défaillant
Retour arrière	R3 (plan de sortie)

12.14 Fiches des anomalies de l'étape 8

A-23 — Critères de phase non mesurables

Élément	Contenu
Anomalie initiale	Critères de phase non mesurables — gravité **Moyenne**, statut de la revue **NON VALIDÉ**
Correction précise	Tous les critères sont réécrits avec **vérité terrain** (jeu étiqueté, contre-expertise d'un échantillon aléatoire, sondes pièges), **bornes de confiance à 95 %** (règle des trois : zéro événement sur n essais indépendants borne le taux à $3/n$) et **tailles d'échantillon** minimales ; la phase 1 est scindée en **1a** (sans HSM) et **1b** (avec HSM). Voir chapitre 12.
Composants concernés	Plan de déploiement, plan de tests
Risques résiduels	Représentativité du jeu d'évaluation

Validations nécessaires	Évaluateur indépendant ; Architecte sécurité externe ; Direction
Chapitre	12

A-24 — Collecte du jeu d'évaluation non planifiée

Élément	Contenu
Anomalie initiale	Collecte du jeu d'évaluation non planifiée — gravité **Majeure**, statut de la revue **NON VALIDÉ**
Correction précise	Nouvelle **phase 3b « collecte encadrée »** : base légale en vigueur, analyse d'impact, responsable de la protection des données indépendant, consentement, coffre dédié (classe `EVALUATION_CONSENTED`), service biométrique et HSM opérationnels, destruction programmée du jeu.
Composants concernés	Plan de déploiement, `BiometricLegalBasis`, coffre
Risques résiduels	Consentement de personnes en situation de dépendance (à encadrer par éthique)
Validations nécessaires	Juriste ; Responsable indépendant de la protection des données ; comité d'éthique
Chapitre	12

A-25 — Retour arrière irréaliste (énumérations, données réelles, clés)

Élément	Contenu
Anomalie initiale	Retour arrière irréaliste (énumérations, données réelles, clés) — gravité **Moyenne**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Cinq classes de retour arrière : **R0** (drapeau ou configuration), **R1** (version logicielle compatible avec les données), **R2** (restauration, double contrôle), **R3** (bascule de fournisseur), **R4** (ré-enveloppement en deux temps : l'ancienne génération de clé reste active jusqu'à vérification). Les valeurs d'énumération ajoutées sont **inertes et conservées** (avancer seulement) ; aucune table contenant des données réelles n'est supprimée avant l'échéance de conservation ; désactivation plutôt que suppression.
Composants concernés	Plan de migration, procédures, `prisma/migrations` futures
Risques résiduels	Retour partiel après des données réelles (par conception)
Validations nécessaires	Architecte sécurité externe
Chapitre	12

A-26 — Biais d'automatisation de la revue humaine

Élément	Contenu
Anomalie initiale	Biais d'automatisation de la revue humaine — gravité **Moyenne**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Revue **en aveugle d'abord** (comparaison sans score ni rang), **sondes pièges** (≥ 2 % des revues, correspondances et non-correspondances connues), temps minimal de revue, **filigrane** du relecteur sur l'écran, double relecture pour les décisions menant à une mesure coercitive, indicateurs (taux d'infirmation, sensibilité et spécificité sur les pièges, accord entre relecteurs), formation et recertification annuelle.
Composants concernés	`biometric/review.ts`, écrans de revue, tableau de bord de qualité
Risques résiduels	La capture d'écran ne peut pas être empêchée (le filigrane dissuade)
Validations nécessaires	Évaluateur indépendant ; Responsable indépendant de la protection des données
Chapitre	12

13. Étape 9 — Décisions D-17 à D-23, fédération avec le Dossier unique national (A-10, A-17, A-18, A-27)



13.1 Fédération sans divulgation sortante

Flux	Direction	Contenu	Base légale	État par défaut
Résolution d'identité	Dossier national → police	Identifiant national, statut	Texte du dossier unique	**Activé**
Événements d'identité (fusion, scission, décès)	Dossier national → police	Type, identifiants	Idem	**Activé**
Fusions décidées par la police	Police → dossier national	Type, identifiants	À créer	**Désactivé** (D-07)
Attestation « possède une biométrie »	Police → dossier national	—	—	**Supprimée** (A-17)
Échange de gabarits ou d'échantillons	—	—	Décision écrite	**Désactivé**

Divulgation sortante future (si une base légale l'exige) : requête limitée à une finalité, approuvée par le responsable de la protection des données, limitée en débit, journalisée, sans révéler l'absence ou la présence hors finalité.

13.2 Procédure de scission (A-18)

1. Événement `PERSON_SPLIT` : le sujet passe en `SPLIT_PENDING` ; **aucune attribution positive** n'est possible.
2. **Attribution de chaque échantillon** à l'une des nouvelles identités par **deux relecteurs indépendants**.
3. Délai de **30 jours** ; à défaut, **mise en quarantaine** (exclusion des galeries).
4. Création des nouveaux sujets ; ré-inscription ; journalisation.

13.3 Pseudonymes, mode dégradé, versionnement

Sujet	Règle
Pseudonyme par système	`HMAC-SHA-256(clé du HSM, référence nationale ‖ « SIGPN-T »)` ; clé non exportable ; rotation avec table de correspondance protégée
Mode dégradé	Dossier injoignable : enrôlement avec **lien en attente** (durée limitée), file d'événements **rejouée de façon idempotente**, délai de 5 s, coupe-circuit ; **aucune recherche opérationnelle bloquée**
Versionnement	Contrat versionné ; **fenêtre de compatibilité de deux versions** ; tests de contrat ; connecteur DEMO
Fusion de fiches locales	Changement de lien, **jamais de déplacement de gabarit** ; doublons de sujets proposés à la revue

13.4 Portabilité et décision D-03 (A-10)

D-03 est contraignant : option B obligatoire (gabarit normalisé + propriétaire + échantillon de référence chiffré). Toute autre option : portabilité **non garantie**, projet **suspendu** tant que le risque n'est pas accepté par écrit. **Format d'archivage** : empreintes sans perte (PNG ou JPEG 2000 sans perte, ISO/IEC 19794-4, ≥ 500 ppp, 1000 ppp si capturé) ; visage ISO/IEC 19794-5 / 39794-5 sans compression destructive ; valeurs à confirmer par l'évaluateur.

13.5 Registre des 23 décisions

N°	Décision	Recommandation	Décideur	Avant	Nature
D-01	Base légale et autorité de contrôle	**B**, avec avis juridique écrit ; autorité de contrôle désignée	Direction générale + Justice	Phase 0	Inchangée
D-02	Hébergement et modèle de fournisseur	**A**, avec exigence de portabilité (D-03) et exploitation précisée par D-23	Direction + responsable du projet	Phase 0	Ajustée
D-03	Portabilité des gabarits (**contraignante**)	**B obligatoire**. Toute autre option : portabilité non garantie, projet suspendu tant que le risque n'est pas accepté par écrit. Format d'archivage sans perte (ISO/IEC 19794-4 ≥ 500 ppp ; visage ISO/IEC 19794-5/39794-5) à confirmer par l'évaluateur	Direction + juridique	Phase 0	Renforcée
D-04	Gouvernance biométrique : profils, personne physique, épinglage	**C**	Direction	Phase 1	Renforcée
D-05	Indépendance et qualité de la revue humaine	**C** ; lignes existantes classées « sans revue indépendante »	Direction + commissaires	Phase 1	Renforcée
D-06	Conservation, bases multiples, précédence preuve / effacement, sauvegardes	**B après avis** ; échéance = maximum des bases actives ; **la conservation de preuve judiciaire l'emporte sur la copie probatoire seulement** ; sauvegardes biométriques ≤ 35 jours, séparées	Juridique + responsable de la protection des données + Justice	Phase 1	Renforcée

D-07	Maître de la donnée et fédération avec le Dossier unique national	**C** ; `attest()` supprimé ; flux sortants désactivés ; aucun gabarit échangé sans décision écrite	Direction + porteur du dossier unique	Phase 0	Révisée
D-08	Fonctionnement hors ligne	**A** pour la biométrie ; **B** à étudier pour les plaques — **après l'enquête de connectivité (D-23)**	Direction + opérations	Phase 6	Conditionnée
D-09	Périmètre de la reconnaissance faciale	**A** ; **C interdit** par un texte	Direction + juridique	Phase 0	Inchangée
D-10	Seuils d'acceptation, méthode statistique et évaluateur	**B** ; évaluateur indépendant du fournisseur ; méthode : bornes de confiance à 95 %, règle des trois, tailles d'échantillon minimales (chapitre 12)	Direction	Phase 0	Précisée
D-11	Constitution de la galerie initiale	**A + B** sous base légale ; **D exclu** sans décision ; mineurs : voir D-17	Direction + juridique	Phase 0	Complétée
D-12	Modalité voix	**A**	Direction	Phase 2	Inchangée
D-13	Budget, HSM, stockage externe, horodatage, licences	Chiffrage avant l'appel d'offres, incluant **deux HSM**, le stockage à écriture seule, le tiers d'horodatage et l'hébergement du service biométrique	Direction	Phase 0	Complétée
D-14	Information et recours des personnes ; phase « ombre »	**A** avant la phase 5 ; procédure de contestation publiée	Direction + juridique	Phase 5	Inchangée
D-15	Notification des incidents	Délai fixé par le juridique	Juridique	Phase 1	Inchangée
D-16	Gouvernance des portes de phase	Comité nommé **avant la phase 0**, **indépendant de l'éditeur et du fournisseur** ; chaque porte **signée** ; validateurs externes associés	Direction générale	Phase 0	Renforcée
D-17	Mineurs	**A** pour la galerie ; **B** seulement par décision spécifique, garanties renforcées, durée réduite ; **C exclu**. Seuil d'âge à confirmer par le juridique	Direction + juridique + juge des enfants	Phase 0	**Nouvelle**
D-18	Échanges internationaux	**A** tant qu'aucun cadre légal n'existe ; **B** ensuite, par accord écrit validé par le responsable de la protection des données ; **aucun gabarit exporté**	Direction + juridique	Phase 0	**Nouvelle**
D-19	Valeur probante et règle de corroboration	**A + règle de corroboration** : aucune mesure coercitive sur la seule base d'un résultat biométrique ; au moins un élément indépendant non biométrique ; droit de contestation immédiat ; expertise judiciaire pour toute utilisation en procédure. À valider avec la Justice	Justice + Direction	Phase 0	**Nouvelle**
D-20	Statut et indépendance du responsable de la protection des données	**B** ou **A avec garanties** : inamovibilité, accès direct à la Direction, ressources propres, aucun cumul avec une fonction opérationnelle, suppléant désigné ; **C exclu**	Direction générale	Phase 0	**Nouvelle**
D-21	Niveau d'assurance du HSM	**A** (ou **B**), **deux HSM** ; **C inacceptable en production**	Direction + architecte sécurité externe	Phase 0	**Nouvelle**
D-22	Accès du parquet aux données biométriques réelles	**A** par défaut ; **C** sur demande motivée écrite, journalisée, par l'intermédiaire du responsable de la protection des données ; jamais d'accès libre	Justice + Direction	Phase 1	**Nouvelle**
D-23	Exploitation de la base de données et du HSM ; enquête de connectivité	**A** pour les rôles sensibles (gardiens, administrateurs de base) ; **B** possible pour l'infrastructure sous surveillance ; **enquête de connectivité avant la phase 7 et avant D-08**	Direction + informatique de la police	Phase 1	**Nouvelle**

Le registre complet (options, conséquences, documents requis) est livré séparément (`REGISTRE_DECISIONS_V1.2`).

13.6 Fiches des anomalies de l'étape 9

A-10 — La portabilité dépend de D-03 ; format d'archivage non défini

Élément	Contenu
Anomalie initiale	La portabilité dépend de D-03 ; format d'archivage non défini — gravité **Majeure**, statut de la revue **DÉCISION REQUISE**
Correction précise	D-03 devient **contraignant** : option B obligatoire (gabarit normalisé + propriétaire + échantillon de référence chiffré) ; toute autre option = portabilité non garantie, projet suspendu tant que le risque n'est pas accepté par écrit. Format d'archivage : empreintes **sans perte** (PNG ou JPEG 2000 sans perte, ISO/IEC 19794-4, ≥ 500 ppp, 1000 ppp si capturé) ; visage ISO/IEC 19794-5 / 39794-5 sans compression destructive ; valeurs à confirmer par l'évaluateur.

Composants concernés	Modèle de données (échantillon), cahier des charges, D-03
Risques résiduels	Volume de stockage des images
Validations nécessaires	Direction ; Juriste ; Évaluateur indépendant
Chapitre	13

A-17 — `attest()` révèle la présence d'une personne dans le fichier biométrique

Élément	Contenu
Anomalie initiale	`attest()` révèle la présence d'une personne dans le fichier biométrique — gravité **Majeure**, statut de la revue **DÉCISION REQUISE**
Correction précise	**`attest()` supprimé.** Le connecteur n'a que des flux **entrants** par défaut (`resolveIdentity`, événements d'identité). Toute divulgation sortante est **désactivée** ; si une base légale future l'exige : requête limitée à une finalité, approuvée par le responsable de la protection des données, limitée en débit, journalisée, sans réponse sur l'absence ou la présence en dehors de la finalité.
Composants concernés	`NationalRegistryConnector`, `BiometricSubjectLink`
Risques résiduels	Évolution du cadre légal
Validations nécessaires	Direction ; Juriste ; Responsable indépendant de la protection des données (D-07)
Chapitre	13

A-18 — Fédération : flux, scissions, pseudonymes, mode dégradé

Élément	Contenu
Anomalie initiale	Fédération : flux, scissions, pseudonymes, mode dégradé — gravité **Moyenne**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Matrice des flux (direction, contenu, base légale, état par défaut) ; **procédure de scission** (sujet suspendu pour toute attribution positive, attribution de chaque échantillon par deux relecteurs, délai de 30 jours, mise en quarantaine à défaut) ; pseudonyme par système = HMAC à clé non exportable du HSM ; **mode dégradé** (enrôlement avec lien en attente, file d'événements rejouée, coupe-circuit, aucune opération de recherche bloquée) ; contrat versionné avec fenêtre de compatibilité de deux versions.
Composants concernés	`NationalRegistryConnector`, `BiometricIdentityEvent`, `persons/service.ts`
Risques résiduels	Spécifications du dossier unique encore inconnues
Validations nécessaires	Architecte sécurité externe ; Juriste ; porteur du dossier unique
Chapitre	13

A-27 — Décisions manquantes

Élément	Contenu
Anomalie initiale	Décisions manquantes — gravité **Moyenne**, statut de la revue **DÉCISION REQUISE**
Correction précise	Ajout de D-17 à D-23 (mineurs, échanges internationaux, valeur probante et corroboration, statut du responsable de la protection des données, assurance du HSM, accès du parquet, exploitation et enquête de connectivité) ; recommandations de D-02, D-03, D-04, D-05, D-06, D-07, D-08, D-11, D-13 ajustées.
Composants concernés	Registre des 23 décisions
Risques résiduels	Décisions tardives
Validations nécessaires	Direction ; Juriste
Chapitre	13

14. Étape 10 — Registre des risques et checklists de validation externe (A-28, A-29, A-30)

14.1 Échelle et classes

Élément	Définition
Probabilité (P)	1 rare · 2 peu probable · 3 possible · 4 probable · 5 quasi certaine
Impact (I)	1 faible · 2 limité · 3 sérieux · 4 grave · 5 critique (atteinte aux droits, perte de confiance)
Niveau	P × I : **Critique ≥ 15** · **Élevé 10–14** · **Moyen 5–9** · **Faible ≤ 4**
Bloquant	Condition non remplie qui **empêche toute phase** (indépendamment du score)

14.2 Registre des 25 risques

N°	Risque	P	I	Brut	Classe brute	Mesures	P×I résiduel	Classe résiduelle	Propriétaire
R-01	Deux chemins de chiffrement à maintenir (`crypto.ts` et coffre)	2	3	6	Moyen	A-13 ; non-modification de `crypto.ts` ; tests MFA	3	Faible	Éditeur
R-02	Falsification ou contournement par un administrateur privilégié de la base	4	5	20	Critique	A-01, A-02, A-03, A-06, A-07	10	Élevé	Architecte sécurité
R-03	Rareté et surcharge des relecteurs	4	3	12	Élevé	D-05 ; réservoir provincial ; indicateurs	6	Moyen	Commissaires
R-04	Résurrection de données effacées via sauvegarde	3	4	12	Élevé	A-04, A-05, A-16	4	Faible	DPO
R-05	Perte de précision lors d'un changement de fournisseur	3	3	9	Moyen	A-09 ; D-03 B	6	Moyen	Éditeur
R-06	Fuite d'images de référence (impact accru par la conservation)	3	5	15	Critique	A-11, A-12, A-13 ; chiffrement ; quotas	10	Élevé	Architecte sécurité
R-07	Spécifications du Dossier unique national inconnues	4	2	8	Moyen	A-18 ; connecteur versionné	4	Faible	Éditeur
R-08	Faux rapprochements de plaques	4	3	12	Élevé	Forme canonique ; revue humaine ; corroboration	6	Moyen	Commissaires
R-09	**Cadre juridique tchadien non confirmé**	5	5	25	Bloquant	D-01, D-17, D-18, D-19, D-20	25	Bloquant	Direction + Justice
R-10	Dérive documentaire	3	2	6	Moyen	Régénération de la documentation à chaque phase	2	Faible	Éditeur
R-11	**Faux positif entraînant une interpellation ou une atteinte aux droits injustifiée**	3	5	15	Critique	D-19 (corroboration) ; revue indépendante en aveugle ; sondes pièges ; expertise ; droit de contestation ; critères des phases 5 et 6	10	Élevé	Direction + Justice
R-12	Biais démographiques de la reconnaissance faciale	3	4	12	Élevé	D-09 ; évaluation par groupes ; seuil d'écart ; limitation à l'aide à la vérification	8	Moyen	Évaluateur
R-13	Défaillance, faillite ou fin de support du fournisseur	3	4	12	Élevé	D-03 B ; clauses de sortie ; essai bi-fournisseur ; entiercement	6	Moyen	Direction
R-14	Panne ou perte du HSM, ou perte du quorum de gardiens	2	5	10	Élevé	Deux HSM ; au moins 3 gardiens ; séquestre testé	5	Moyen	Architecte sécurité
R-15	Compromission d'une clé maîtresse	2	5	10	Élevé	A-13 ; procédure de compromission ; quotas ; ré-enveloppement en deux temps	5	Moyen	Architecte sécurité
R-16	Oracle de déballage : compromission du service biométrique	3	5	15	Critique	A-11 ; service séparé ; quotas ; coupe-circuit	8	Moyen	Architecte sécurité
R-17	Divulgation indirecte de la présence d'une personne au Dossier unique	3	4	12	Élevé	A-17 ; `attest()` supprimé ; flux sortants désactivés	4	Faible	DPO
R-18	Biais d'automatisation des relecteurs	4	4	16	Critique	A-26 ; revue en aveugle ; pièges ; indicateurs	9	Moyen	DPO

R-19	Donnée réelle utilisée avant le statut du fournisseur ou hors cadre (collecte)	3	5	15	Critique	A-08, A-24 ; classes de données ; statuts de fournisseur ; garde en base	5	Moyen	DPO
R-20	Abus par un initié (recherches sans motif, détournement)	4	4	16	Critique	Cible partie à l'affaire ; alertes d'anomalie ; revue du DPO ; sanctions	9	Moyen	DPO
R-21	Contournement de la séparation des fonctions par plusieurs comptes d'une même personne	3	4	12	Élevé	A-19 ; `StaffIdentity` ; réconciliation hebdomadaire	4	Faible	Responsable des ressources humaines
R-22	Restauration utilisée pour falsifier l'historique (retour en arrière)	3	5	15	Critique	A-04 ; double contrôle natif ; comparaison aux ancrages externes	5	Moyen	Architecte sécurité
R-23	Indisponibilité du service ou procédures manuelles défaillantes	3	3	9	Moyen	Procédure manuelle ; haute disponibilité ; coupe-circuit	6	Moyen	Opérations
R-24	Collecte inappropriée de données de mineurs	2	5	10	Élevé	D-17	5	Moyen	Direction + juridique
R-25	Détournement de finalité (usage hors mission légale)	2	5	10	Élevé	Finalité inscrite dans la base légale ; audit externe ; DPO indépendant (D-20)	8	Moyen	DPO

Reclassements majeurs. R-09 (cadre juridique) : **Bloquant**. R-11 (faux positif entraînant une interpellation injustifiée) : **Critique** avant mesures ; **jamais sous « Élevé »** après mesures (risque irréductible). R-02 (falsification par privilégié) : **Critique** avant mesures.

14.3 Checklists de validation externe (remplacent celles de l'auteur)

A. Architecte sécurité externe

1. Rôles PostgreSQL : aucun superutilisateur ni propriétaire côté application ; tests d'attaque 42501 rejoués.
2. Registre chaîné : preuve de chaînage, signature par le HSM, ancrage externe ; essai de falsification.
3. Restauration : quorum natif, quarantaine, comparaison aux ancrages, rejeu du registre d'effacement externe.
4. Service biométrique : aucun point de déchiffrement en masse ; quotas et coupe-circuit testés.
5. HSM : quorum, rôles séparés, assurance (D-21), double site, séquestre.
6. Format `bv2` et données authentifiées associées ; cycle de vie et compromission simulée.
7. Épinglage des droits : déclencheur de base, éligibilité par type d'approbation.
8. Classes de données et statuts de fournisseur : refus par le service et par la base.
9. Pseudonymes et connecteur : aucune divulgation sortante.
10. Zones réseau, absence de sortie des moteurs.
11. Revue de code des contrôles critiques ; test d'intrusion.
12. `crypto.ts` non modifié ; suite MFA verte.

B. Juriste

1. Base légale du traitement (D-01) ; autorité de contrôle.
2. Mineurs (D-17) ; échanges internationaux (D-18).
3. Valeur probante, **règle de corroboration**, droit de contestation (D-19).
4. Durées, bases multiples, précédence preuve / effacement, « mise hors d'usage » des sauvegardes (D-06).
5. Interdiction de l'identification faciale en temps réel dans l'espace public (D-09).
6. Information des personnes et procédure de contestation (D-14).
7. Conditions de la collecte du jeu d'évaluation et du consentement (phase 3b).
8. Fédération : flux et absence de divulgation sortante (D-07).
9. Accès du parquet (D-22) ; notification des incidents (D-15).
10. Contrats : clauses de portabilité, de sortie, de suppression, de localisation.

C. Responsable indépendant de la protection des données

1. Indépendance et moyens du responsable (D-20).
2. Analyse d'impact complète.

3. Minimisation : sondes non conservées, échantillons de référence justifiés.
4. Registre d'effacement externe, démonstration d'un effacement bout en bout.
5. Qualité de la revue humaine : en aveugle, pièges, indicateurs.
6. Détection d'usage anormal : seuils, procédure, sanctions.
7. Droits des personnes : accès, contestation, effacement.
8. Vérification quotidienne de l'ancrage : procédure indépendante de l'exploitation.
9. Séparation au niveau des personnes : réconciliation hebdomadaire.
10. Registre des risques : exhaustivité et reclassements.

14.4 Fiches des anomalies de l'étape 10

A-28 — Registre des risques incomplet et sous-évalué

Élément	Contenu
Anomalie initiale	Registre des risques incomplet et sous-évalué — gravité **Moyenne**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Registre à 25 risques avec échelle probabilité × impact, classes **Bloquant** / **Critique** / **Élevé** / **Moyen** / **Faible**, niveau brut et résiduel, propriétaire. R-09 (cadre juridique) reclassé **Bloquant** ; R-11 (faux positif entraînant une interpellation injustifiée) classé **Critique**, jamais sous « Élevé » après mesures.
Composants concernés	Registre des risques
Risques résiduels	Risques non identifiés
Validations nécessaires	Architecte sécurité externe ; Juriste ; Responsable indépendant de la protection des données
Chapitre	14

A-29 — Checklist rédigée par l'auteur

Élément	Contenu
Anomalie initiale	Checklist rédigée par l'auteur — gravité **Mineure**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	Checklist remplacée par **trois checklists de validation externe** (architecte sécurité, juriste, responsable indépendant de la protection des données) avec preuves attendues ; l'auteur n'évalue pas ses propres critères.
Composants concernés	Chapitre 14.3
Risques résiduels	—
Validations nécessaires	Les trois validateurs externes
Chapitre	14

A-30 — Imprécisions diverses

Élément	Contenu
Anomalie initiale	Imprécisions diverses — gravité **Mineure**, statut de la revue **VALIDÉ SOUS RÉSERVE**
Correction précise	`BiometricMatch` : `subjectId` obligatoire pour les lignes réelles, `personId` interdit ; `BIOMETRIC_MODE` scellé (modification = redéploiement approuvé + alerte, lecture seule pour l'application) ; clés d'idempotence conservées 24 h puis purgées ; filigrane pour la comparaison éphémère ; contrôle d'intégrité de la configuration au démarrage.
Composants concernés	`env.ts`, orchestrateur, schéma
Risques résiduels	—
Validations nécessaires	Architecte sécurité externe
Chapitre	14

15. Modèle de données consolidé v1.2



Règle de migration : uniquement additive, avancer seulement (énumérations inertes), **rien n'est appliqué par ce document**.

15.1 Tables existantes conservées (chemin DEMO, inchangées)

`FingerprintRecord`, `FaceRecord`, `VoiceRecord` (marqueur `templateFormat = 'DEMO_SHA256'` verrouillé), `LicensePlateDetection`, `BiometricSearch`, `BiometricMatch`, `BiometricControl`.

15.2 Colonnes ajoutées

Table	Colonnes
`BiometricSearch`	`requestedById`, `providerCode`, `engineVersion`, `thresholdUsed`, `galleryScope`, `latencyMs`, `jobId`, `scoreScale`, `dataClass`
`BiometricMatch`	`subjectId`, `scoreRaw`
`BiometricControl`	`providerCode`, `matchedSubjectId`
`LicensePlateDetection`, `WantedVehicle`, `TrafficVehicle`	`plateCanonical` (indexé) ; en plus sur la lecture : `trafficVehicleId`, `watchStatus`, `confidence`, `source`
`Officer`, `User`	rattachement à `StaffIdentity`
`IdentifierType` (énumération)	valeur `NATIONAL_UNIQUE_ID` (inerte si inutilisée)

15.3 Nouvelles tables

Table	Contenu
`BiometricSubject`, `BiometricSubjectLink`, `BiometricIdentityEvent`	Sujet stable, liens (fiche locale, identifiant national, pseudonyme), événements de fusion, scission, décès
`BiometricSample`, `BiometricTemplate`, `BiometricEnrollment`	Échantillon de référence chiffré (`bv2`) avec **classe de données**, gabarits normalisé et propriétaire, une inscription par fournisseur
`BiometricSampleBasis`	Bases légales multiples
`BiometricCapture`	Capture signée, nonce, durée ≤ 15 min
`BiometricProvider` (statut, classes admises), `BiometricDevice`, `BiometricKey`	Fournisseurs, appareils, métadonnées de clés
`BiometricLegalBasis`, `BiometricRetentionPolicy`, `BiometricRetentionEvent`, `BiometricRetentionRun`	Conservation
`BiometricErasureRequest`, `BiometricErasureRegister`	Effacement ; registre **répliqué hors base**
`BiometricJob`, `BiometricReview`, `BiometricReviewAssignment`, `BiometricControlEvent`, `BiometricWatchHit`, `BiometricProviderHealth`	Recherches, décision unique, escalade, états de contrôle, indications, santé
`BiometricLedger`, `BiometricLedgerCheckpoint`	Registre chaîné et points de contrôle signés
`StaffIdentity`	Personne physique

15.4 Contraintes et garde-fous

1. **Écriture seule** et immuabilité (chapitre 6.4) ; `isDemo` immuable.
2. **Étanchéité DEMO / réel** ; gabarit `DEMO_SHA256` jamais associé à une inscription réelle.
3. **Classes de données** ↔ statut de fournisseur (chapitre 11).
4. `BiometricControl_simulation_only` reste en vigueur dans les environnements de démonstration ; remplacement en production seulement (chapitre 20).
5. Épinglage des droits (déclencheur sur `RolePermission`).
6. Précédence : la base fait foi pour le statut des fournisseurs ; `BIOMETRIC_MODE` est un plafond **scellé** (modification = redéploiement approuvé + alerte).

16. API et contrats fournisseurs consolidés

16.1 Routes existantes (contrats inchangés, enveloppes minces)

`POST …/fingerprint|face|voice/enroll` · `…/search` · `…/anpr/detect` · `…/anpr/search` · `GET …/history[/{id}]` · `PATCH …/history/{id}` · `GET/POST …/control[/{id}]`. Mode demo : comportement actuel exact ; mode réel : même contrat, règles du nouveau modèle.

16.2 Nouvelles routes

Chemin	Permission ou authentification	Objet
`POST /biometric/captures`	certificat d'appareil + capture signée	Dépose une capture
`POST /biometric/jobs` · `GET /jobs/{id}`	droit de recherche	Identification 1:N / vérification 1:1 asynchrones
`POST /biometric/reviews` · `GET/POST /review-assignments`	`biometric:verify` + affectation	Décision unique, réservoir
`POST /biometric/enrollments` · `/{id}/validate`	`biometric:manage` · `biometric:enroll_validate`	Enrôlement, validation indépendante
`GET/PATCH /biometric/hits`	`biometric:watchlist_review`	Indications
`GET/POST/PATCH /biometric/providers`	`biometric:provider_manage` (statuts par approbation)	Cycle de vie des fournisseurs
`GET/POST/PATCH /biometric/devices`	`biometric:device_manage`	Appareils
`POST /biometric/keys/rotate`	`biometric:key_manage` + **quorum du HSM**	Rotation
`GET /biometric/retention/policies` · `POST /retention/run`	`biometric:retention_manage`	Conservation
`POST/PATCH /biometric/erasure-requests`	création : agent habilité ; décision : `erasure_decide`	Effacement
`POST /biometric/portability/exports`	`biometric:export_portability` + approbations	Export gouverné
`GET /biometric/subjects/{id}`	`biometric:history_view_candidates`	Vue minimale
`POST /biometric/identity-events`	connecteur signé	Fusion, scission, décès
`GET /biometric/health`	`biometric:provider_manage`	Santé
`POST /api/v1/webhooks/biometric/{provider}`	signature du fournisseur (route publique, limitation dédiée)	Résultats asynchrones, idempotents

Conventions : clé d'idempotence obligatoire (24 h puis purge) ; l'API `/api/v1` n'évolue que par ajout de champs ; valeurs de décision : `NO_CANDIDATE`, `REVIEW_REQUIRED`, `UNAVAILABLE` (**aucune décision automatique**) ; l'indice n'est **jamais** présenté comme une probabilité.

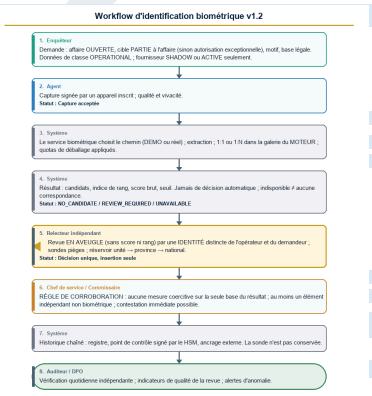
16.3 Contrats des fournisseurs

Les **quatre interfaces** de `types.ts` restent inchangées. Extensions facultatives (spécification) :

```
type ProbeInput = { kind: "image"; data: Buffer; format: string; dataClass: DataClass } | { kind: "template";
interface ProviderExtensions {
  capabilities(): Promise<ProviderCapabilities>;   // isDemo doit égaler la base ; portability{...}
  health(): Promise<{ ok: boolean; latencyMs: number; version: string }>;
  assessQuality(sample: Buffer): Promise<{ standard: "NFIQ2" | "ISO_29794_5"; score: number; ok: boolean }>;
  enroll(subject: { subjectRef: string }, samples: SampleInput[], opts: { requestId: string }): Promise<{ enro
  identifyInGallery(probe: ProbeInput, opts: { gallery: string; maxCandidates: number; threshold: number; requ
  remove(enrollmentId: string): Promise<{ deleted: boolean; proof: string }>;
  exportGallery?(opts: { gallery: string }): AsyncIterable<{ enrollmentId: string; standardTemplate?: Template
}
```

Règles communes : rejet de `DEMO_SHA256` ; gabarit normalisé et ré-inscription depuis images **obligatoires** ; export de galerie et **preuve de suppression** ; idempotence ; taxonomie d'erreurs fermée ; pas de conservation des sondes ; hébergement sur site ; **refus d'une classe de données non admise par le statut**.

17. Workflows



Règles : demande (affaire **ouverte**, cible **partie à l'affaire**, base légale) → capture signée (classe `OPERATIONAL`, fournisseur `SHADOW`/`ACTIVE`) → recherche → résultat sans décision → recoupement en lecture seule → **revue en aveugle** par un relecteur d'**identité distincte** (réservoir, escalade 24 h / 48 h) → décision unique → **corroboration obligatoire avant toute mesure coercitive** → historique chaîné, signé, ancré → contrôle a posteriori. **Enrôlement** : capture, qualité, vivacité, preuve d'identité, détection de doublons, **validation indépendante**, base légale, classe, inscription. **Effacement** : demande → décision du DPO → clé enveloppée supprimée + registre externe + suppression côté moteur avec preuve → sauvegardes ≤ 35 jours.

18. Rôles et permissions (préservation des 29 rôles et des 158 droits)

Garantie	Détail
29 rôles	**Aucun droit retiré** ; ajouts additifs soumis au circuit d'approbation ; `SUPER_ADMIN` et `SECURITY_ADMIN` **inchangés**
158 droits	Aucun renommé ni retiré ; liste des droits sensibles : ajout seulement
Nouveaux droits (10)	`enroll_validate`, `watchlist_review`, `provider_manage`, `device_manage`, `export_portability`, `key_manage`, `retention_manage`, `erasure_decide`, `history_view_candidates`, `governance_approve` → **168**
Nouveaux profils (3)	`BIOMETRIC_PLATFORM_ADMIN`, `KEY_CUSTODIAN` (≥ 3 identités), `DATA_PROTECTION_OFFICER` → **32** rôles ; verrouillés, sans droit opérationnel
Visibilité de l'historique	Lignes DEMO : inchangée ; lignes réelles : métadonnées pour les 12 détenteurs de `history_view` ; candidats réservés à l'opérateur, au demandeur, aux relecteurs, à l'équipe d'affaire, au DPO et à l'auditeur

19. Plan de tests et de validation

19.1 Tests existants à conserver

`tests/unit/biometric*.test.ts`, `tests/integration/biometric.test.ts`, `biocontrol.test.ts` ; `tests/unit/auth-primitives.test.ts`, `mfa-switch.test.ts`, `tests/security/auth.test.ts` (**MFA et chiffrement**) ; `tests/unit/admin-separation.test.ts`, `tests/integration/admin-separation.test.ts` ; `tests/unit/sensitivity.test.ts` ; test des libellés FR/AR ; `tests/security/route-matrix.test.ts` ; toutes les suites existantes (169 unitaires, 287 d'intégration, 34 de sécurité au dernier passage).

19.2 Nouveaux tests

Famille	Contenu	Critère
Attaque base de données	UPDATE/DELETE/TRUNCATE/DISABLE TRIGGER/CREATE/`session_replication_role` en tant que `pms_app` ; tripwire	100 % refusés
Intégrité	Falsification de chaque colonne, suppression, rejeu ; vérification de chaîne, de signature, d'ancrage	100 % détectées ≤ 15 min
Restauration	Quorum, quarantaine, retour en arrière détecté, rejeu du registre d'effacement	Conforme
Coffre	Quotas, coupe-circuit, substitution de chiffré (AAD), compromission simulée, perte de quorum	Conforme
Personnes physiques	Double compte, gardiens distincts, revue d'identités	100 %
Épinglage	Attribution d'un droit de gouvernance à un autre rôle ; approbation par un titulaire de `approvals:decide` seul	100 % refusés
Classes de données	Classe non admise ↔ statut ; association interdite (service **et** base)	100 % refusés
Fédération	Fusion, scission, décès, mode dégradé, absence de divulgation sortante	Conforme
Portabilité	Essai bi-fournisseur, ré-inscription depuis images	Seuil du 11.3
Qualité de la revue	Sondes pièges, aveugle, indicateurs	Seuils du 12
Existants adaptés	Sensibilité, libellés, routes, décomptes, contrat de l'historique (`visibility`)	Verts

19.3 Évaluation indépendante

Organisme indépendant du fournisseur et de l'éditeur (D-10) ; ISO/IEC 19795 ; jeu local constitué sous protocole (phase 3b) ; mesures et seuils du chapitre 12 ; réévaluation à chaque changement de version d'algorithme ou de fournisseur.

20. Plan de migration depuis le mode DEMO

Donnée	Décision
Gabarits `sha256` de démonstration (81 empreintes, 26 visages en base de développement)	**Restent en démonstration**, jamais copiés en production
Lectures de plaques et contrôles simulés	Restent, étiquetés

Historique DEMO (206 recherches, 387 contrôles)	Conservé, `isDemo = vrai`, exclu des statistiques opérationnelles

Étapes (aucune appliquée) : migrations additives **avancer seulement** ; registre des fournisseurs (`mock-*` en `isDemo = vrai`) ; modes `demo`/`shadow`/`operational` **scellés** ; bandeau DEMO levé **fournisseur par fournisseur** ; remplacement de `simulation_only` **uniquement en production** après approbation de deux profils ; bascule modalité par modalité. **Conditions préalables de bascule** : autorisation institutionnelle, avis juridique, analyse d'impact, évaluation indépendante conforme, test d'intrusion, **rapports des trois validateurs externes**, approbation du responsable du projet.

21. Fichiers et composants existants susceptibles d'être modifiés (repérage, aucun n'est modifié)

Fichier ou composant	Évolution éventuelle	Anomalies
`deploy/docker-compose.yml`, `deploy/entrypoint.sh`, `deploy/backup/*`	Rôles distincts, migrations séparées, sauvegardes biométriques dédiées	A-01, A-04, A-16
`prisma/schema.prisma` + nouvelles migrations (avancer seulement)	Chapitre 15 ; **migration `20261108140000_biometric_control` non modifiée**	A-02, A-06, A-07
`src/server/db.ts`, `src/server/env.ts`	Tripwire ; variables ; mode scellé	A-01, A-30
`src/server/crypto.ts`, `auth/login.ts`	**Non modifiés**	—
`src/server/audit.ts`, `audit-chain.ts`	Ancrage de `AuditLog` ; nouveaux types d'événements	A-02, A-03
`src/server/biometric/*` (service, control, schemas, queries, actions)	Délégation au service biométrique ; revue unique ; contrôles insertion seule	A-07, A-11, A-22
`src/server/biometric/providers/*`	Extensions facultatives ; statuts et classes de données	A-08, A-09
`src/server/persons/service.ts`	`mergePersons` émet un événement d'identité	A-18
`src/server/cases/service.ts`, `wanted/service.ts`, `evidence/service.ts`	Événements de conservation ; copies probatoires	A-14, A-15
`src/server/rbac/*`, `admin/roles.ts`, `admin/users.ts`	Dix droits, trois profils, épinglage, identité d'agent	A-19, A-20, A-21
`src/server/approvals/*`	Nouveaux types, éligibilité par type	A-20
`src/server/api.ts`	Limite de débit dédiée aux webhooks biométriques	—
`src/app/api/v1/biometric/**`, `(app)/biometric/**`	Enveloppes ; revue en aveugle ; filigrane	A-26
`src/lib/i18n/*`, `navigation.ts`	Libellés FR/AR	A-22
`tests/**`	Chapitre 19	A-22
Nouveaux	Service biométrique, registre chaîné, ancrage, restauration, `StaffIdentity`, connecteur DEMO, adaptateurs réels	—

22. Soumission aux validateurs externes

Cette version est **conditionnée** à la revue de **trois validateurs indépendants** : un **architecte sécurité externe**, un **juriste**, un **responsable indépendant de la protection des données** (checklists du 14.3). Les réserves critiques ouvertes bloquent toute autorisation. **L'implémentation reste interdite** tant que ces trois rapports ne sont pas remis et que la Direction n'a pas autorisé par écrit.

Rappel de la consigne. Cette version est un document de conception. Aucun code, aucune table, aucune donnée, aucune configuration n'ont été modifiés ; aucune migration n'a été exécutée ; les marqueurs DEMO sont conservés ; aucun moteur réel n'est connecté ; aucun commit n'a été poussé.

Annexe A — Tableau de traçabilité des 30 anomalies

N°	Gravité	Statut de la revue	Étape	Chapitre	Correction (résumé)	Composants	Risques résiduels	Validations nécessaires

A-01	Critique	NON VALIDÉ	1	5	Cinq rôles PostgreSQL distincts : propriétaire de schéma sans connexion ; migrateur utilisé seulement au déploiement ; rôle applicatif sans DDL, sans TRIGGER, sans TRUNCATE, ni superutilisateur, ni propriétaire ; rôle du service biométrique sur base dédiée ; rôle de sauvegarde en lecture seule.	deploy/docker-compose.yml, deploy/entrypoint.sh (migrations hors du conteneur applicatif), deploy/backup/*, prisma/schema.prisma (URL de migration distincte), src/server/db.ts (tripwire), src/server/env.ts, scripts SQL […]	Superutilisateur de secours existant (scellé, alerté) ; collusion de deux administrateurs ; le poste de développement conserve un superutilisateur (hors production)	Architecte sécurité externe (revue des rôles et de pg_hba) ; exécution des tests d'attaque en préproduction ; test d'intrusion ciblé
A-02	Critique	NON VALIDÉ	2	6	Registre biométrique chaîné (BiometricLedger) alimenté par des fonctions SECURITY DEFINER à chaque insertion de recherche, correspondance, revue, événement de contrôle et décision d'effacement : empreinte canonique de la ligne, chaînage (hash = SHA-256(prevHash ‖ seq ‖ type ‖ id ‖ rowHash ‖ date)), verrou consultatif comme pour AuditLog.	Nouvelles tables BiometricLedger, BiometricLedgerCheckpoint ; fonctions et déclencheurs ; service d'ancrage ; tâche de vérification ; src/server/audit-chain.ts (extension à l'ancrage) ; stockage externe à écriture seule	Compromission simultanée de la base, du HSM et du support externe ; fenêtre de 15 minutes couverte par l'expédition en temps réel mais non nulle	Architecte sécurité externe (preuve de la chaîne et de l'ancrage) ; essai de falsification par une équipe indépendante ; Responsable indépendant de la protection des […]
A-03	Majeure	VALIDÉ SOUS RÉSERVE	2	6	Support externe à écriture seule dans un autre domaine d'administration (stockage à verrouillage d'objet, ou serveur de journaux dédié hors du périmètre des administrateurs de la plate-forme) ; fréquence : temps réel (empreintes), 15 min (points de contrôle signés), quotidienne (ancrage horodaté) ; vérificateur : auditeur + responsable […]	Service d'ancrage (nouveau), deploy/*, procédure d'exploitation	Dépendance au tiers d'horodatage ; coût du stockage externe	Architecte sécurité externe ; Responsable indépendant de la protection des données
A-06	Majeure	VALIDÉ SOUS RÉSERVE	2	6	Liste exhaustive : BiometricSearch — aucune colonne modifiable pour les lignes réelles (insertion seule) ; pour les lignes isDemo = vrai seules les colonnes historiques action, actionNotes, actionById, actionAt restent modifiables ; isDemo est immuable dans tous les cas (déclencheur).	prisma/schema.prisma (migrations additives), déclencheurs, biometric/service.ts	Les anciennes lignes DEMO restent modifiables (comportement conservé volontairement)	Architecte sécurité externe ; tests d'attaque (UPDATE de chaque colonne, bascule de isDemo)
A-07	Majeure	VALIDÉ SOUS RÉSERVE	2	6	Pour les contrôles réels (isSimulation = faux) : ligne insertion seule ; transitions d'état dans BiometricControlEvent (insertion seule) ; décision humaine uniquement dans BiometricReview ; les champs reviewed* du contrôle deviennent dérivés en lecture seule.	biometric/control.ts, biometric/review.ts (nouveau), queries.ts, écran de contrôle	Période de double lecture (anciens et nouveaux champs) jusqu'à la fin de la phase 6	Architecte sécurité externe ; non-régression tests/integration/biocontrol.test.ts

A-04	Majeure	NON VALIDÉ	3	7	Restauration biométrique à double contrôle natif : les sauvegardes sont chiffrées par une clé de sauvegarde enveloppée par le HSM, déchiffrable seulement avec le quorum de gardiens (2 sur 3).	deploy/backup/*, procédure de restauration (nouvelle), service d'ancrage, HSM	Fenêtre de perte des données postérieures au point de restauration (inévitable) ; disponibilité du quorum de gardiens	Architecte sécurité externe ; exercice de restauration observé par l'auditeur ; Responsable indépendant de la protection des données
A-05	Majeure	NON VALIDÉ	3	7	Registre d'effacement répliqué en continu hors de la base (journal externe à écriture seule, entrées signées par le HSM : identifiant, date, décision du responsable de la protection des données), conservé au moins 125 jours (35 jours de sauvegarde + 90 jours de marge ; recommandation : 1 an).	BiometricErasureRegister (table + miroir externe), biometric/retention.ts (nouveau), procédure de restauration	Délai entre l'effacement et la réplication (fermé par la réplication synchrone du miroir)	Architecte sécurité externe ; Responsable indépendant de la protection des données ; Juriste (valeur de la « mise hors d'usage » en sauvegarde)
A-16	Moyenne	VALIDÉ SOUS RÉSERVE	3	7	Base biométrique dédiée (cluster ou base distincte, rôle distinct) ; sauvegarde principale de l'application exclut le schéma biométrique ; sauvegarde biométrique séparée, verrouillage d'objet à 35 jours, clé de sauvegarde détruite à l'échéance ; contrôle automatique que la sauvegarde principale ne contient aucune table biométrique.	deploy/backup/*, deploy/docker-compose.yml, configuration de la base biométrique	Deux cycles de sauvegarde à exploiter	Architecte sécurité externe ; contrôle de l'auditeur
A-11	Majeure	NON VALIDÉ	4	8	Service biométrique séparé (processus, identité, hôte et réseau distincts) : l'application web n'a jamais accès aux clés ni aux échantillons en clair ; API étroite (recevoir une capture, inscrire, rechercher, matériel de revue éphémère, effacer) sans point de déchiffrement en masse.	Nouveau service biométrique, biometric/vault.ts (déplacé dans le service), src/server/biometric/service.ts (client), deploy/*	Compromission du service biométrique lui-même (surface réduite, quotas limitant l'exfiltration)	Architecte sécurité externe ; test d'intrusion visant l'exfiltration massive
A-12	Majeure	VALIDÉ SOUS RÉSERVE	4	8	Quorum natif du HSM (carte à puce, 2 sur 3 au minimum) pour générer, détruire une clé maîtresse et déchiffrer les sauvegardes ; rôles HSM séparés (officier de sécurité, officier de chiffrement, auditeur) tenus par des personnes différentes ; deux HSM synchronisés ; niveau d'assurance exigé (D-21).	HSM (nouveau), service de clés, procédure de cérémonie	Perte simultanée de gardiens (≥ 3 titulaires, séquestre)	Architecte sécurité externe ; audit de la cérémonie ; D-21
A-13	Moyenne	VALIDÉ SOUS RÉSERVE	4	8	Chapitre complet (états, rotation, compromission, panne et remplacement du HSM, séquestre, départ d'un gardien, agilité cryptographique).	biometric/vault.ts, key-service.ts, procédures	Erreur humaine en cérémonie (exercices annuels)	Architecte sécurité externe ; exercice de compromission simulée
A-19	Majeure	NON VALIDÉ	5	9	Identité d'agent (StaffIdentity) vérifiée sur pièce, unique par personne physique, rattachée à la fiche agent et au compte.	Nouvelle table StaffIdentity, Officer, User (liaison), admin/users.ts, approvals/*, biometric/review.ts	Pièce d'identité falsifiée ou complicité à l'enregistrement	Architecte sécurité externe ; Responsable indépendant de la protection des données ; Direction (D-04)

A-20	Majeure	NON VALIDÉ	5	9	Épinglage : chaque droit de gouvernance n'est attribuable qu'à son profil (contrôle dans le code d'édition de rôles et dans l'exécuteur d'approbation, et déclencheur de base sur RolePermission) ; matrice d'éligibilité par type d'approbation : les nouveaux types exigent biometric:governance_approve de deux identités et de deux profils […]	rbac/permissions.ts, roles.ts, grants.ts, admin/ roles.ts, approvals/rules.ts et service.ts, déclencheur sur RolePermission	Modification du code par un développeur (contrôle de version et revue)	Architecte sécurité externe ; revue du code d'approbation
A-21	Moyenne	VALIDÉ SOUS RÉSERVE	5	9	Attribution uniquement par une demande approuvée par le commandement national et le responsable de la protection des données ; l'administrateur de sécurité ne peut ni créer ni attribuer ces profils ; premier titulaire désigné par décision écrite de la Direction lors d'une cérémonie d'amorçage témoin et journalisée.	rbac/grants.ts, approvals/*, procédure d'amorçage (nouvelle)	Amorçage fondé sur la confiance en la décision écrite	Direction ; Responsable indépendant de la protection des données
A-22	Moyenne	VALIDÉ SOUS RÉSERVE	5	9	Liste des tests à adapter (sensibilité, libellés FR/AR, matrice de routes, décomptes de documentation) ; la réponse de l'historique porte un champ visibility explicite (FULL pour les lignes DEMO, METADATA ou FULL selon le profil pour les lignes réelles) ; test de contrat versionné.	tests/unit/sensitivity.test.ts, tests/security/route-matrix.test.ts, biometric/ queries.ts, i18n	Oubli d'un test lors de l'implémentation (liste de contrôle)	Architecte sécurité externe ; revue de la liste de tests
A-14	Moyenne	NON VALIDÉ	6	10	Table BiometricSampleBasis (échantillon ↔ affaire ou décision, début, fin) ; échéance = maximum des bases actives ; les événements de conservation sont émis par les statuts de partie (CLEARED, CHARGED…) et les issues d'affaire ; effacement seulement quand plus aucune base n'est active ; calcul documenté et testé.	Nouvelles tables, cases/ service.ts, persons/ service.ts (émission d'événements), biometric/ retention.ts	Qualification juridique des bases (à confirmer)	Juriste ; Responsable indépendant de la protection des données
A-15	Moyenne	DÉCISION REQUISE	6	10	Règle de précédence proposée : la conservation de preuve judiciaire l'emporte tant que l'affaire est ouverte, mais ne porte que sur la copie probatoire (pièce avec chaîne de possession) ; l'échantillon de référence opérationnel est effacé selon la politique ; toutes les copies sont inventoriées et rattachées au registre d'effacement ; […]	evidence/service.ts, retention.ts, registre d'effacement	Désaccord d'interprétation juridique	Juriste ; Responsable indépendant de la protection des données ; Justice
A-08	Majeure	NON VALIDÉ	7	11	Procédure réordonnée : conformité (données synthétiques) → évaluation indépendante → approbation en mode ombre → ré-inscription par lot → double fonctionnement → approbation de bascule.	BiometricProvider, BiometricSample, BiometricEnrollment, BiometricJob, orchestrateur, déclencheurs	Erreur d'étiquetage de la classe de données (contrôles automatiques et audit)	Architecte sécurité externe ; Juriste ; Responsable indépendant de la protection des données

A-09	Majeure	VALIDÉ SOUS RÉSERVE	7	11	Essai bi-fournisseur en phase 3 : ré-inscription d'un jeu synthétique ou sous licence de l'AFIS A vers l'AFIS B depuis les images, et mesure de l'écart de précision (critère : dégradation relative du FNMR ≤ [20 %] au même FMR) ; test d'échange de gabarits normalisés documenté ; clause du marché imposant au soumissionnaire de fournir un […]	Plan de tests, cahier des charges, outil de ré-inscription	Perte de précision inévitable sur gabarit normalisé (l'image est la voie de référence)	Évaluateur indépendant ; Architecte sécurité externe
A-23	Moyenne	NON VALIDÉ	8	12	Tous les critères sont réécrits avec vérité terrain (jeu étiqueté, contre-expertise d'un échantillon aléatoire, sondes pièges), bornes de confiance à 95 % (règle des trois : zéro événement sur n essais indépendants borne le taux à $3/n$) et tailles d'échantillon minimales ; la phase 1 est scindée en 1a (sans HSM) et 1b (avec HSM).	Plan de déploiement, plan de tests	Représentativité du jeu d'évaluation	Évaluateur indépendant ; Architecte sécurité externe ; Direction
A-24	Majeure	NON VALIDÉ	8	12	Nouvelle phase 3b « collecte encadrée » : base légale en vigueur, analyse d'impact, responsable de la protection des données indépendant, consentement, coffre dédié (classe EVALUATION_CONSENTED), service biométrique et HSM opérationnels, destruction programmée du jeu.	Plan de déploiement, BiometricLegalBasis, coffre	Consentement de personnes en situation de dépendance (à encadrer par éthique)	Juriste ; Responsable indépendant de la protection des données ; comité d'éthique
A-25	Moyenne	VALIDÉ SOUS RÉSERVE	8	12	Cinq classes de retour arrière : R0 (drapeau ou configuration), R1 (version logicielle compatible avec les données), R2 (restauration, double contrôle), R3 (bascule de fournisseur), R4 (ré-enveloppement en deux temps : l'ancienne génération de clé reste active jusqu'à vérification).	Plan de migration, procédures, prisma/ migrations futures	Retour partiel après des données réelles (par conception)	Architecte sécurité externe
A-26	Moyenne	VALIDÉ SOUS RÉSERVE	8	12	Revue en aveugle d'abord (comparaison sans score ni rang), sondes pièges (≥ 2 % des revues, correspondances et non-correspondances connues), temps minimal de revue, filigrane du relecteur sur l'écran, double relecture pour les décisions menant à une mesure coercitive, indicateurs (taux d'infirmation, sensibilité et spécificité sur les […]	biometric/review.ts, écrans de revue, tableau de bord de qualité	La capture d'écran ne peut pas être empêchée (le filigrane dissuade)	Évaluateur indépendant ; Responsable indépendant de la protection des données
A-10	Majeure	DÉCISION REQUISE	9	13	D-03 devient contraignant : option B obligatoire (gabarit normalisé + propriétaire + échantillon de référence chiffré) ; toute autre option = portabilité non garantie, projet suspendu tant que le risque n'est pas accepté par écrit.	Modèle de données (échantillon), cahier des charges, D-03	Volume de stockage des images	Direction ; Juriste ; Évaluateur indépendant

A-17	Majeure	DÉCISION REQUISE	9	13	attest() supprimé.	NationalRegistryConnector, BiometricSubjectLink	Évolution du cadre légal	Direction ; Juriste ; Responsable indépendant de la protection des données (D-07)
A-18	Moyenne	VALIDÉ SOUS RÉSERVE	9	13	Matrice des flux (direction, contenu, base légale, état par défaut) ; procédure de scission (sujet suspendu pour toute attribution positive, attribution de chaque échantillon par deux relecteurs, délai de 30 jours, mise en quarantaine à défaut) ; pseudonyme par système = HMAC à clé non exportable du HSM ; mode dégradé (enrôlement avec […]	NationalRegistryConnector, BiometricIdentityEvent, persons/service.ts	Spécifications du dossier unique encore inconnues	Architecte sécurité externe ; Juriste ; porteur du dossier unique
A-27	Moyenne	DÉCISION REQUISE	9	13	Ajout de D-17 à D-23 (mineurs, échanges internationaux, valeur probante et corroboration, statut du responsable de la protection des données, assurance du HSM, accès du parquet, exploitation et enquête de connectivité) ; recommandations de D-02, D-03, D-04, D-05, D-06, D-07, D-08, D-11, D-13 ajustées.	Registre des 23 décisions	Décisions tardives	Direction ; Juriste
A-28	Moyenne	VALIDÉ SOUS RÉSERVE	10	14	Registre à 25 risques avec échelle probabilité × impact, classes Bloquant / Critique / Élevé / Moyen / Faible, niveau brut et résiduel, propriétaire.	Registre des risques	Risques non identifiés	Architecte sécurité externe ; Juriste ; Responsable indépendant de la protection des données
A-29	Mineure	VALIDÉ SOUS RÉSERVE	10	14	Checklist remplacée par trois checklists de validation externe (architecte sécurité, juriste, responsable indépendant de la protection des données) avec preuves attendues ; l'auteur n'évalue pas ses propres critères.	Chapitre 14.3	—	Les trois validateurs externes
A-30	Mineure	VALIDÉ SOUS RÉSERVE	10	14	BiometricMatch : subjectId obligatoire pour les lignes réelles, personId interdit ; BIOMETRIC_MODE scellé (modification = redéploiement approuvé + alerte, lecture seule pour l'application) ; clés d'idempotence conservées 24 h puis purgées ; filigrane pour la comparaison éphémère ; contrôle d'intégrité de la configuration au démarrage.	env.ts, orchestrateur, schéma	—	Architecte sécurité externe